

Gap Analysis and Project Roadmap

An evidence-based review of what is finished, what is missing, and the order in which the remaining work should be done to bring tourismislife.com to a complete, trustworthy, enquiry-led website.

PREPARED
7 October 2026

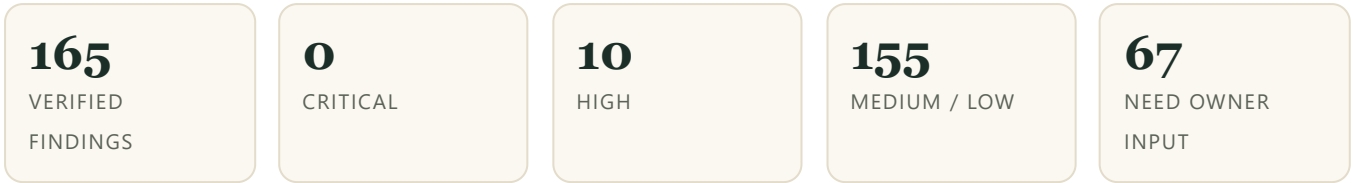
SCOPE
**tourismislife.com codebase
and live site**

METHOD
**8 audits, adversarial
verification**

Prepared from a read-only audit of the codebase, the local development build and the public site. No production data was read or changed, no forms were submitted, and no secret values were viewed. Items marked Owner depend on content, data, accounts or decisions that only Tourism Is Life can supply. Effort ratings (S, M, L) are indicative engineering estimates, not quotes.

Executive summary

The engineering foundation is sound, but the project is not finished. Production is running code from 22 September while two weeks of work, including the privacy and terms pages, sits uncommitted on one laptop. The public site still sends visitors on 16 of 22 tours into an online seat-hold and payment flow that the business does not offer. Several published prices, ratings, claims and images have no recorded source or permission. Most of what remains is alignment, operations, compliance and content rather than deep technical work: with prompt decisions from the owner, the site can reach a launch-ready state in an estimated two to three weeks of focused engineering, with content depth following over the next two months.



The audit covered eight areas: product and content, data and operations, security, the dormant commerce code, search visibility, performance and accessibility, quality and delivery, and legal and image rights. Each area was examined by an independent read-only auditor working from the current code and live behaviour. Every critical and high finding was then handed to a second reviewer whose only job was to refute it; the severities in this report are the verified ones.

The strongest parts of the project are its code quality and security model: typecheck, lint and all 313 tests pass on a clean copy, there are no known dependency vulnerabilities, no secret has ever been committed, and every administrative function checks permissions on the server. The weakest parts are process and operations: two weeks of work has never been committed or deployed, CI has never run, the admin account is unclaimed, staff cannot yet manage enquiries from the system, backups cover only six hours, and nothing alerts the team when something fails.

The single most important step is the simplest: commit, review and deploy the work that already exists, so the live site matches the reviewed code. Everything else in the roadmap builds on that.

Readiness by area

AREA	MATURITY	ASSESSMENT
Product and content completeness	partial	Honest foundations and consistent contact details, but tours invite online booking, several numbers are unsourced, internal audit wording shows to visitors, and core travel-planning pages (FAQ, travel information, visa guidance) do not exist.
Data, backend and operations	partial	Migrations, schema and the save-then-email enquiry flow are sound. Operations are not: no admin owner, no enquiry desk, six hours of backup, no monitoring, and an enquiry is lost if the database is down.
Security, authentication and admin access	partial	Strong code-level model (server-side role checks, CSRF, Zod, zero npm vulnerabilities, no leaked secrets). Real exposure is operational: unclaimed admin behind open sign-up, an undisclosed third-party script, and missing browser security headers.
Dormant commerce, accounts and vouchers	partial	The booking engine is well built and cannot move money today, but it is not dormant: it is the main call to action on 16 tours and dead-ends at a payment screen that alerts nobody. Needs a single off switch.

SEO and discoverability	 partial	Every page has a unique title, description and canonical, and structured data exists. Held back by a sitemap missing about 70 pages, share cards overwritten site-wide, soft 404s, and no analytics or Search Console.
Performance, accessibility and responsiveness	 partial	Code splitting, reduced-motion support, landmarks and layout from 320 to 1920 px are solid. Weak on image delivery (34 MB of full-size JPEG, 6 to 9 MB fetched on the homepage before scrolling), a build defect that would ship unstyled pages on the next deploy, and keyboard and ARIA gaps around the carousels.
Quality assurance, CI/CD and repository health	 partial	All gates pass and reproduce on a clean copy: 0 type errors, 0 lint issues, 313 tests with 0 failures, build OK. The weakness is process: two weeks of work uncommitted, CI never run, no branch protection, local dev wired to the production database, no monitoring and no runbooks.
Legal, compliance, brand and image rights	 partial	Privacy, terms, cookies and image-credit pages now exist and read honestly. Gaps: undisclosed third-party script, enquiries copied to an outside mailbox, newsletter without consent or unsubscribe, 24 live images without a recorded licence, and unsourced claims.

SECTION 2

What stands between the project and "finished"

For an enquiry-led destination management website, **finished** means five things are true at once. **1.** Production runs the reviewed code, from a repository with working CI, and can be restored from a tested backup. **2.** Every page leads to an enquiry or quote request, and none invites booking or payment. **3.** Every published price, rating, claim, image and data flow has a recorded source, permission or legal basis. **4.** Staff can receive, track and answer every enquiry from the admin desk, and are alerted when something fails. **5.** Visitors can find the practical information they need to plan a trip, and search engines can find every page. The blockers below are the gaps against that definition, in order of priority.

Launch blockers

#	ISSUE	WHY IT MATTERS	EFFORT
1	Production is two weeks behind the codebase, and CI has never run HIGH REPO-1, CI-1, OPS-8, SEC-12	Live /privacy, /terms and /cookies return 404. 114 changed paths and the CI workflow are uncommitted; main is unprotected and every push deploys straight to production.	S
2	The next deploy would ship unstyled pages HIGH PERF-1	Builds of the current code link a stylesheet that is not emitted. The live site is fine today (stylesheet returns 200), so this must be fixed and checked before the Phase 0 deploy.	S
3	Tours invite an online booking flow the business does not offer HIGH BK-1, PC-1, BK-2, BK-3, PC-6	On 16 of 22 tours the only call to action leads to a seat hold and a payment screen that cannot complete; details are stored but nobody is told. Breaks product rule 1.	M
4	Published prices and ratings with no source HIGH LEG-6, PC-2, PC-3, PC-15, BK-11, BK-12	Vehicle rates and availability, templated tour ratings and 2024 cruise prices are live, while the Terms say no prices are published. Breaks product rule 2.	S + Owner
5	Local development is wired to the production database HIGH QA-OPS-1	Any local test, migration or form submission can change live data. A separate development database is needed before more work is done.	S
6	Data-protection gaps in forms MEDIUM LEG-4, LEG-5, LEG-7, OPS-9	Every enquiry is copied to an external UK mailbox not named in the policy; the newsletter has no consent wording, confirmation or unsubscribe.	M + Owner
7	Undisclosed third-party script on every page MEDIUM LEG-1, SEC-2, SEO-1, PLAT-1	A grok.com script loads on every page including login and admin, sets a third-party cookie, and strips each page's own share metadata.	S
8	Image rights not recorded for 24 live images MEDIUM LEG-2, LEG-3, LEG-10	Includes the homepage coast-and-islands hero, the logo and all 21 vehicle photos, which appear to be stock from other countries.	S + Owner
9	Admin account unclaimed; password reset broken MEDIUM SEC-1, OPS-1, BK-6, OPS-2	Whoever first registers the bootstrap address claims permanent super-admin rights. Reset requests are rejected while the page promises an email.	S (Owner)

10	No backups beyond six hours, no monitoring, no runbook MEDIUM OPS-3, MON-1, DOC-2	The database sits on a personal free-tier account with no snapshots; failures reach only server logs; there is no written deploy, rollback or restore procedure.	M + Owner
11	Enquiries can be lost, and staff cannot work them MEDIUM OPS-5, OPS-6, OPS-4, TST-1	A database error loses the enquiry with no email fallback; rate limiting is ineffective; the admin list has no reference, date, notes, reply or export; the path has no tests.	M

What is already strong

- All quality gates pass on a clean copy: 0 type errors, 0 lint issues, 313 tests with 0 failures, and the build succeeds.
- npm audit reports zero vulnerabilities, and no secret has ever been committed.
- Every admin function re-checks the user's role on the server; all 12 authenticated functions reject anonymous callers; SQL is parameterised and inputs are validated.
- Migrations are restored and run on each build, the schema matches the code, and enquiries are saved before any email is sent.
- No money can move: no tour has a price and payment webhooks fail closed.
- Approved contact details are consistent across 100+ pages, and all 147 internal links resolve.
- Every content page has a unique title, description and canonical, is server-rendered, and carries structured data where it fits.
- Per-page JavaScript is 186 to 218 KB compressed, reduced-motion support works, and layouts hold from 320 to 1920 px.

Decisions only the owner can make

- **Claim the admin account now** from the bootstrap address, then confirm one super-admin exists.
- **Booking code:** remove it, or keep it behind an off switch (recommended), or keep it as is.
- **Prices and ratings:** supply a source for vehicle rates, cruise prices and tour ratings, or approve their removal.
- **Enquiry recipients:** confirm whether the external UK mailbox should receive every enquiry, and on what basis.
- **Grok platform features:** confirm they can be removed from the live site.
- **Primary domain:** the bare domain already redirects to www, so canonicals should move to www (or the redirect should be reversed).
- **Stay and Dine:** keep in the menu as a labelled preview, or hide until real listings exist.
- **Image rights** for 24 images, and the source of the homepage island aerial.
- **Claims:** evidence for 1 DCM World membership, AFAR mention, licensed guides, and consent for the testimonial and staff photos.
- **Accounts and hosting:** move the database to a business-owned account on a plan with longer backup history.
- **Process:** approve committing the pending work, protecting the main branch, and deploying through pull requests.
- **Legal review** of privacy, terms and cookies by a qualified lawyer.
- **Content supply:** FAQ answers, travel facts, fuller itineraries and team biographies.

Roadmap

The roadmap is ordered by dependency and risk. Phase 0 makes the live site match the reviewed code and puts the company in control of its own systems. Phases 1 and 2 close the gaps against the firm product rules and data-protection basics; together they define launch-ready. Phase 3 makes the business runnable from the system. Phases 4 and 5 build depth and growth. Timings assume one developer and prompt owner input; owner-dependent items are tagged. Finding references point to the register in Section 4.

At a glance

PHASE	WHEN	OUTCOME
Phase 0 · Secure and ship what is already built	Week 1	Production matches the reviewed code, and the company controls its own accounts and data.
Phase 1 · Align the site with the enquiry-only model	Weeks 1 to 3	No page invites booking or payment, and every number shown has a source.
Phase 2 · Compliance and trust	Weeks 2 to 5	Every claim, image and data flow on the site is documented and approved. Launch-ready
Phase 3 · Make the business runnable	Weeks 3 to 7	Staff can run every enquiry from the system and are told when something breaks.
Phase 4 · Content depth	Weeks 4 to 10	A visitor can plan a trip without contacting the desk for basic facts.
Phase 5 · Growth and optimisation	Month 3 onward	Reach more of the right travellers and partners.

Phase 0 · Secure and ship what is already built

WEEK 1

Production matches the reviewed code, and the company controls its own accounts and data.

- Owner claims the super-admin account from the bootstrap address; confirm exactly one super-admin exists. Owner (SEC-1, OPS-1)
- Create a separate development database and point local development at it, so local work can never touch live data. (QA-OPS-1)
- Fix the stylesheet mismatch in the build and add a check that every linked asset exists. (PERF-1)
- Review, commit and push the 114 pending changes including the CI workflow, through a pull request; protect the main branch; deploy; confirm /privacy, /terms and /cookies return 200 and the pages are styled. Owner (REPO-1, CI-1, OPS-8, SEC-12)
- Put a daily database backup and branch protection in place, write and test a one-page deploy, rollback and restore runbook, and move the database into a business-owned account on a plan with longer recovery. Owner (OPS-3, DOC-2)

- Remove the Grok head injector and its third-party script so each page keeps its own share metadata. (LEG-1, SEC-2, SEO-1, PLAT-1)
- Add baseline browser security headers, and move canonicals to www to match the live redirect. (SEC-3, SEO-3)

Done when: Live site equals the reviewed repository, CI gates every change, local work is isolated from production, a restore has been tested, and no third-party script loads.

Phase 1 • Align the site with the enquiry-only model

WEEKS 1 TO 3

No page invites booking or payment, and every number shown has a source.

- Add one booking switch (off by default); make 'Request a quote' and the enquiry form the call to action on every tour; block and noindex the booking and checkout routes; remove the 'Self-serve bookable' filter. (BK-1, PC-1, BK-4, BK-13)
- Rewrite the shared tour FAQ and all hold, voucher and payment wording in enquiry language. (PC-6, BK-2)
- Remove vehicle rates, availability badges, tour ratings and cruise prices unless the owner supplies a current source; align the Terms. Owner (PC-2, PC-3, PC-15, LEG-6, LEG-13)
- Fix password reset and surface sign-in errors, require email verification or close public sign-up, and decide whether the account area is needed at all. (OPS-2, SEC-4, BK-7, BK-8, SEC-6)
- Make enquiries resilient: email the desk if the database write fails, add timeouts, a honeypot and a durable rate limit; make demo payments and the in-memory database impossible in production. (OPS-5, OPS-6, OPS-10, OPS-14, BK-5, SEC-5)
- Replace internal audit wording with customer-facing copy; correct the Cotton Tree text; fix sideways photos; return real 404s for unknown pages. (PC-4, PC-11, PC-16, PC-18, SEO-4)

Done when: A visitor can only enquire; every price, rating and availability label has a recorded source or is gone; a database outage cannot lose an enquiry.

Phase 2 • Compliance and trust

WEEKS 2 TO 5

Every claim, image and data flow on the site is documented and approved.

- Name every enquiry recipient in the privacy policy and in a short notice above each submit button, or stop the external copy. Owner (LEG-4, OPS-9)
- Newsletter: consent line, double opt-in, unsubscribe link, stored consent record, and a staff view and export. (LEG-5, OPS-11)
- Complete the privacy, terms and cookies pages and have them reviewed by a lawyer; self-host fonts to stop sharing visitor IP addresses with third parties. Owner (LEG-7, LEG-15, LEG-16, LEG-8, PC-27)
- Resolve rights for the 24 unlicensed live images, replace the stock vehicle photos, and drop the island aerial slide until its source is confirmed. Owner (LEG-2, LEG-3, LEG-10, LEG-9)
- Source or remove third-party claims (1 DCM World, AFAR, licensed guides) and record consent for the testimonial and staff photos. Owner (LEG-11, LEG-12, LEG-19)

Done when: Phases 0 to 2 complete = launch-ready: the site is honest, lawful as far as the owner's counsel advises, and owned by the company.

Phase 3 • Make the business runnable

WEEKS 3 TO 7

Staff can run every enquiry from the system and are told when something breaks.

- Build the enquiry desk: reference, date, parsed fields, statuses (new, in progress, quoted, closed), notes, assignee, reply by email or WhatsApp, search, filters and export. (OPS-4)
- Add error monitoring, an uptime check and a health endpoint; record email delivery outcomes and alert on failed team notifications. (MON-1, OPS-7)
- Support privacy deletion requests from the admin. (OPS-15)
- Set up cookieless analytics, Google Search Console and Bing Webmaster; generate the sitemap from the catalogue (about 100 pages); noindex auth and booking pages; remove duplicate journal URLs. Owner (SEO-10, SEO-2, SEO-5, SEO-6, PC-19)
- Add tests for enquiries, newsletter, role checks and rate limiting, a browser smoke test in CI, a guard for the product rules, dependency alerts and an audit step. (TST-1, TST-2, TST-4, OPS-19, CI-2)
- Clean the repository of stale documents and leftover research folders. (PC-28, LEG-20)
- Accessibility fixes: visible skip link, keyboard-safe carousels that pause on focus, 3:1 form borders, unique field ids, autocomplete hints, mobile menu focus handling. (A11Y-1 to A11Y-7)
- Image delivery: lazy-load below-the-fold images, stop preloading hidden slides, generate responsive WebP and AVIF sizes, add cache headers for images, self-host fonts. (PERF-2, PERF-3, PERF-6, PERF-4)

Done when: Every enquiry has an owner and a status, the team is alerted to failures, and search engines can see the whole site.

Phase 4 • Content depth

WEEKS 4 TO 10

A visitor can plan a trip without contacting the desk for basic facts.

- Publish FAQ, Travel Information (arrival at Lungi and transfers, health, money, safety, best time to visit), Visa and Entry with a link to the official portal, How Enquiries Work, and Partner Onboarding. Owner (PC-5)
- Deepen the 16 core tour itineraries and practicalities, the destination pages, and the Guinea, Liberia and West Africa pages; file tours under the correct country. Owner (PC-12, PC-21, PC-10, PC-9)
- Publish real journal articles and hide empty categories; expand About and Team with biographies; give each service its own photograph. Owner (PC-8, SEO-11, PC-20, PC-13)
- Collect real reviews through a public platform and link them; improve titles, descriptions and structured data. (PC-7, SEO-7, SEO-8, SEO-9, SEO-12)
- Replace or remove the footer link to the placeholder 'coming soon' page. (PC-17)

Done when: Every tour and destination page answers what, when, how long, what is included and how to enquire.

Phase 5 • Growth and optimisation

MONTH 3 ONWARD

Reach more of the right travellers and partners.

- Dependency upgrades (55 outdated, 11 a major version behind) and removal of unused packages and Grok scaffolding. (DEP-1, DEP-2, REPO-2, PERF-5)
- French-language pages for the Guinea market, with hreflang. (SEO-13)
- Google Business Profile and complete local business data. Owner (SEO-16)

- Stay and Dine with real partner listings, or retire the preview. **Owner** (PC-14)
- Enforce a content security policy; move email DMARC from monitoring to enforcement through the DNS provider. **Owner** (SEC-3, SEC-11)
- Revisit online payments only if the owner changes the product rule; Section 4 lists what that would require. **Owner** (BK-14)

Done when: Growth work is measured against the analytics set up in Phase 3.

Findings register

Every finding below was reported with evidence by a read-only auditor. Critical and high findings were then re-checked by an independent skeptic who tried to refute them; the severity shown is the verified one, and findings that did not survive are listed in the appendix. "Owner" marks items that need content, data, an account or a decision from Tourism Is Life.

Product and content completeness

29 findings · partial

The site has honest foundations: approved contact details are consistent, all 147 internal links resolve, legal pages exist, and the sustainability page, cruise page, brochure and four long-form itineraries are credible. The main problems are a public online-booking hold flow that breaks the firm no-booking rule, unsourced numbers (tour ratings, vehicle and cruise prices), and internal audit-style wording leaking into visitor copy. Most of the 16 core tours are thin placeholders, Guinea, Liberia and West Africa are shallow, and there is no FAQ, travel information, visa guidance or getting-there content. The Cotton Tree copy, sideways photographs and tour-to-destination mislabelling are fixable code or copy changes. All checks ran against localhost:8080 (GET plus Playwright in Edge), so production behaviour is unverified.

ID	SEVERITY	FINDING	RECOMMENDATION	EFFORT
PC-1	HIGH verified, adjusted	Online seat-hold and checkout flow is publicly reachable from 16 of 22 tours, against the no-booking rule Visitors are pushed into a hold-and-pay funnel that the owner has ruled out, and the site contradicts its own terms. Holds write real rows to the database. The core catalogue has no enquiry form on the tour page itself. Whether a payment can complete in production is unverified, since no Stripe or Monero keys appear in .env.local.	Make bookable:false the effective state for all tours, or add a single site-level flag. Change the card CTA to 'Request a quote' and the tour sidebar to 'Send an enquiry' with the on-page EnquiryForm for every tour. Gate or noindex /booking/* and /checkout/*, and remove them from internal links. Keep the code dormant.	M
PC-2	HIGH verified	Vehicle rental publishes unsourced exact USD daily rates, availability labels and named fleet Owner Specific prices, availability and fleet claims the company has not confirmed. Rule 2 (never invent facts) is broken, and the claims conflict with the Terms. Possible consumer or reputational exposure if the real fleet or rates differ.	Remove prices, 'Available'/'Limited' and the 'What you see is what you pay' claim. Show categories and seat capacity only, with 'Rates on request'. Restore rates only from an owner-supplied rate card. Replace or verify the vehicle photos.	M
PC-3	MEDIUM verified, adjusted	Tour ratings and review counts look templated and are unsourced Owner Repeating figures look fabricated to a careful reader. Rule 2 forbids unsourced ratings and reviews. The star line sits next to a 'No moderated reviews' message, which undermines trust.	Hide catalogue ratings unless the owner can supply the original review source (platform, date, link) per tour. Otherwise remove rating and reviewCount, or replace them with real reviews linked to a TripAdvisor or Google listing.	S
PC-4	MEDIUM verified, adjusted	Internal audit and provenance wording is shown to visitors across many pages A prospective client sees developer notes and hedged third-person text instead of a confident operator voice. Credibility drops on the homepage, contact page and every enquiry confirmation.	Rewrite these as first-person operator copy ('We reply within one working day', 'Our team'). Move provenance notes to code comments or the owner brief. Keep one honest attribution only where a claim needs it, such as the 1 DCM World membership.	M

PC-5	MEDIUM verified, adjusted	No FAQ, travel information, visa and entry guidance, getting there, safety, best time, press or partner onboarding content Owner A credible DMC site answers pre-booking questions: entry, health, getting there, safety, how enquiries work and how operators onboard. Their absence raises enquiry friction and loses search traffic, and the Terms push the visa and health responsibility onto the traveller without any guidance.	Add enquiry-led pages: FAQ, Travel Information (arrival at Lungi and ferry or boat transfer, entry and health, money, safety, best time), a Visa and Entry page with a link to the official e-visa portal, How Enquiries Work, and Partner Onboarding. Owner or official sources must supply the facts. Do not invent requirements.	L
PC-6	MEDIUM verified, adjusted	The generic tour FAQ describes a booking flow and is wrong on all 22 tour pages Quote-only and custom trips are described as having held seats and payment events. The text contradicts the Terms and the enquiry model. Health advice is non-specific.	Replace baseFaqs with enquiry-model answers: how quotes work, how long replies take, what is confirmed in writing, what the traveller arranges, and a link to official health guidance. Drop 'voucher' and 'hold' language.	S
PC-7	MEDIUM	The single homepage testimonial is four words with no source Owner A short, unattributed quote reads as filler. The platform and consent are unknown.	Confirm where it came from (probably a YouTube or social comment) and get the reviewer's consent, or replace it. Collect three to five real, attributed, dated reviews (name, country, trip) and link to the public review profile.	S
PC-8	MEDIUM	The journal is four stub posts and five of eight categories are empty Owner Journal is a primary nav item but holds almost no content. Stubs and empty category pages are thin, duplicated pages and weak trust signals.	Hide empty categories, point the second article URL's canonical at the first, and noindex stubs. Either write real posts (destination guides, trip reports, practical tips) or demote Journal from the main nav until there are 6 or more real posts.	M
PC-9	MEDIUM	Guinea, Liberia and West Africa tours are filed under Sierra Leone places and circuits Visitors are told a Liberian park safari visits Tiwai Island and that a Guinea trek is in the Northern Circuit. The map and location labels are wrong for non-Freetown tours.	Add an optional circuit or destination for non-Sierra Leone tours, or exclude them from circuit and destination listings. Show a proper location label (name, not slug). Remove the fixed Freetown map for tours that do not start there.	M
PC-10	MEDIUM	Guinea, Liberia and West Africa country pages are placeholders Owner The multi-country positioning is thinly supported. Photos of Sierra Leone stand in for Guinean and Liberian places.	Either write short country pages (what the company can arrange, entry notes, sample routes) with real photographs, or present Guinea and Liberia only as a 'multi-country on request' note under Mano River Triangle until content exists.	M
PC-11	MEDIUM	Cotton Tree copy and image alt text still imply the tree stands Visitors expect a standing landmark. An inaccurate alt text is also an accessibility and credibility problem.	Reword to 'the Cotton Tree site / the fallen Cotton Tree memorial' everywhere, change the alt text to describe the stump, and say 'former Cotton Tree site' for the pickup point.	S

PC-12	MEDIUM	The 16 core tours have placeholder-level itineraries and practicalities Owner The core catalogue cannot sell a trip. It gives no times, stops, distances, accommodation names or pickup points.	Get day-by-day content, real pickup points and tour-specific photos from the owner for each tour, starting with the six day trips and the three-day circuits. Do not invent details to fill gaps.	L
PC-13	MEDIUM	All seven service pages use the Atlantic Hotel photo and are about 40 words Owner Wrong imagery, unsupported partner claims and almost no content on a core service.	Pass service.image and imageAlt to PageHero. Rewrite each service page with what is covered, what the client sends and how long it takes. Name the insurer and hotel partners only if confirmed by the owner.	M
PC-14	MEDIUM	Stay & Dine preview sits in the main nav with sample listings and one real hotel Owner Not misleading in-page, but real visitors reach a prototype on a live business site, can enquire about places that do not exist, and the real hotel's name appears without confirmed involvement.	Remove Stay & Dine from the nav until real listings exist, or keep it as an unlinked preview. If kept, drop the real hotel name or get its permission, and make the enquiry CTA say clearly that the listing is a sample. Owner decision.	S
PC-15	MEDIUM	Cruise excursion prices from a 2024 proposal are published against the Terms Owner Stale or unconfirmed prices could bind or embarrass the company. The named individual may no longer hold the role.	Ask the owner to confirm current rates or replace them with 'from' bands or 'rates on request'. Confirm Sonia Koroma's role before keeping her name public. Keep the sourced provenance in code only.	S
PC-16	MEDIUM	Sideways photographs are live on public pages A visibly rotated photo on a client case-study page looks careless.	Re-export both images upright, or replace them with verified correct images. Update the dependent alt text.	S
PC-17	MEDIUM	/coming-soon is a placeholder linked from every page's footer Owner A dead-end placeholder on every page, advertising unconfirmed roadmap items.	Remove the footer link and the route (or redirect to /contact). Do not advertise Senegal, a French site or eco-lodge partnerships until they are confirmed.	S
PC-18	MEDIUM	Unknown tour, service, journal or destination slugs show a crash screen, not a 404 Mistyped or old external links to tour pages land on an error screen with a 200 status, which is a soft 404 for search engines. Whether production builds behave the same is not verified.	Resolve the record in a route loader or beforeLoad and throw notFound() there so SSR returns 404 and renders the notFoundComponent.	S
PC-19	MEDIUM	Sitemap lists only 29 URLs and omits every tour, destination, service and article page The pages that sell trips are not offered to crawlers. The host mismatch may cause duplicate-host signals (not tested against production).	Generate the sitemap from catalog.ts at build time and include every detail page. Confirm the canonical host with the owner and make SITE.website match it.	S

PC-20	MEDIUM	About, Team and Why Us are thin, and team bios are never shown Owner Trust pages for a destination company carry almost no proof: no history, licences, memberships beyond one interview citation, or guide profiles.	Add a short company story with the 2013 founding, render the team bios, add guide profiles, and add licences, memberships and insurance only as the owner supplies documents. Remove 'as stated by the CEO' phrasing.	M
PC-21	MEDIUM	Destination pages are shallow and repeat one summary sentence Owner Destination pages are the main search entry for a DMC and offer almost nothing beyond the card text.	Write per-destination sections (highlights, how to get there, typical time needed, linked tours) from owner-confirmed facts, and make the photo disclaimer accurate or drop it.	L
PC-22	MEDIUM	Enquiry forms exist only after client hydration and an auth session call The main conversion form is blank without JavaScript and blocked if the session endpoint is slow or fails. The enquiry email is the only conversion path now that booking should be off.	Render the form unconditionally and fill the email from the session only when it resolves. Keep email and phone visible as fallbacks on form pages.	S
PC-23	LOW	A Taste of West Africa itinerary skips day 33 Owner A visible gap in the flagship 44-day route.	Add the missing day from the source itinerary, or renumber if the day was merged.	S
PC-24	LOW	Homepage search ignores Month and Travelers Two of three controls in the hero search do nothing.	Remove the unused fields, or carry them into the enquiry form as 'travel month' and 'party size'.	S
PC-25	LOW	House-voice slips and visible jargon Small voice inconsistencies and internal jargon visible to visitors.	Edit the strings, rename the headings to 'Plan a trip' and 'Operator enquiry', and choose one spelling (British, matching most copy).	S
PC-26	LOW	Thin indexable cruise sub-pages and /contact/travel have no inbound links Orphaned near-empty pages that dilute the site if crawled.	Redirect them to the matching /cruise anchors or noindex them. Remove /contact/travel in favour of /contact.	S
PC-27	LOW	Legal pages need owner or counsel review and omit cancellation and governing-law terms Owner Reasonable starting documents, but unreviewed by a lawyer. Cruise terms on /cruise (50% deposit, cancellation fees apply) are not mirrored in /terms.	Have a local lawyer review them. Add governing law, a cancellation and refund summary and a data-retention period.	M
PC-28	LOW	Stale repo docs and a leftover source tree still hold the retired phone number The number is not served, but a copy-paste from the old tree could reintroduce it. Stale docs mislead future work.	Delete or archive attachments/extracted and the stale reports, and refresh CLAUDE.md's open-items list.	S
PC-29	LOW	Unverified-provenance images are in public use Owner Licence and location accuracy are unknown for photos shown on the homepage and the vehicle page.	Ask the owner for the source and place of each supplied image, or swap in verified images, before launch.	S

Data, backend and operations

21 findings ·  partial

The database and backend are sound for what is actually live. Migrations are restored and run on every production build, the schema matches the code, and the enquiry flow writes to the database before it emails, so a Resend failure cannot lose the lead. Typecheck and lint are clean and the test run ends with 118 passing and 0 failing. The weak part is operations. Nobody can currently run the business from this system. /admin is documented as unclaimed and password reset cannot work. The admin enquiry screen is a bare list with no reference, date, reply, notes or export. There is only 6 hours of database recovery, no monitoring, and effectively no rate limiting on the public forms. If the database is down, an enquiry is lost with no fallback email. Production also runs code from 22 Sep: /privacy, /terms and /hospitality return 404 there, and the newer work exists only on one laptop. The cron and hold-expiry gap is not a real defect while online booking is out of scope.

ID	SEVERITY	FINDING	RECOMMENDATION	EFFORT
OPS-1	MEDIUM verified, adjusted	SUPER_ADMIN is unclaimed, and the claim is open to anyone who registers the allowed email Owner If the allowed address is guessable, for example a published mailbox, an outsider can take SUPER_ADMIN. That gives access to all enquiry PII and the ability to grant roles. The window has been open since at least 25 Sep. While it stays unclaimed, no staff member can see enquiries in-system either.	The owner should register with the BOOTSTRAP_ADMIN_EMAIL address and claim SUPER_ADMIN now, then confirm that the Staff list shows one SUPER_ADMIN. After that, add email verification (sendVerificationEmail through the existing Resend sender, plus requireEmailVerification) so that role grants can never rest on an unverified address.	S
OPS-2	MEDIUM verified	Password reset cannot work, and the page tells the user a link will follow Any staff member or customer who forgets a password is locked out and no email is ever sent. For the sole SUPER_ADMIN the only recovery is a manual database edit, and Neon history is 6 hours (OPS-3). The page gives false assurance.	Implement emailAndPassword.sendResetPassword with sendEmail (Resend is already live). Switch the client to authClient.requestPasswordReset and check the returned `error`. Do the same for sign-in and sign-up. Add tests, and verify the full loop once in a browser with a real mailbox.	M
OPS-3	MEDIUM verified, adjusted	Only 6 hours of database recovery, no snapshots, and the data sits in a personal free-tier Neon account Owner An accidental DELETE, a bad migration, or a logout fix gone wrong that is noticed after 6 hours is unrecoverable. Enquiries, newsletter subscribers, accounts and staff roles are the only durable copy of leads. The business has no control of its own data store if the account changes hands.	Add a scheduled logical backup (for example a GitHub Actions pg_dump to private storage, daily) and enable branch protection. Decide on a paid plan with at least 7 days of point-in-time restore. Move the Neon project into a business-owned organisation. Write a short restore runbook and test it once.	M
OPS-4	MEDIUM verified, adjusted	Staff cannot manage enquiries from the admin screen A caller quoting their ENQ reference cannot be found. Nothing says whether an enquiry has been answered, by whom, or how old it is. Anything beyond the newest 100 enquiries is unreachable from the UI. A fault looks like an empty inbox. Staff must keep working from the shared mailbox instead.	Build the enquiry-led desk. Show the reference, date and parsed fields (phone, dates, travellers). Add statuses new, in progress, quoted and closed with an internal notes field and an assignee. Add 'Reply by email' and WhatsApp buttons prefilled with the reference. Add search, filters, pagination, CSV export, and honest error and empty states. Do not add payments or online booking.	L

OPS-5	MEDIUM verified, adjusted	A database failure loses the enquiry completely, with no email fallback A Neon outage, a cold-start timeout, or a connection fault on the site's only conversion path means the lead is lost. The visitor gets a technical message and the desk never hears of it.	Wrap the insert in try/catch and log.error with the ref. On failure, still email the desk the full payload marked 'NOT SAVED to database'. Show the visitor a plain message pointing to the approved phone numbers or WhatsApp. Add connectionTimeoutMillis (about 5 s) and one retry.	S
OPS-6	MEDIUM	Rate limiting is effectively off in production, and each enquiry triggers outbound mail to a visitor-supplied address A script can flood the desk inbox and the partner CC. It can use the site to send receipts to arbitrary third-party addresses, damaging sender reputation on the info@ domain. It can burn the Resend quota, after which genuine notifications fail silently. The Resend plan limits are not known.	Add a hidden honeypot field and a minimum-fill-time check. Optionally add a free CAPTCHA such as Turnstile. Back the limiter with the existing Postgres (a small counter table) or Upstash. Cap the daily outbound sends. Consider sending the receipt only for requests that pass these checks.	S
OPS-7	MEDIUM	Email notification outcome is not recorded, there is no monitoring, and the admin desk is unreachable If Resend rejects, throttles, or the sender setup breaks, enquiries stay 'open' in the database and nobody is told. The failure is visible only to someone reading recent logs.	Add team_notified_at and notify_error columns on enquiries and show a 'not emailed' badge in the admin list. Add an error tracker or at least Vercel alerts. Add an external uptime check on the home page. Add a weekly digest of unanswered open enquiries. Do one live end-to-end test after each deploy.	M
OPS-8	MEDIUM	Production is running 22 Sep code, and the newer work exists only on one laptop Owner The live site has no privacy or terms page. A single laptop failure would lose weeks of work. The next deploy will ship many unreviewed changes at once, and its `npm run build` will run db:migrate against the production Neon database.	Review, commit and push the work. Let CI pass. Deploy deliberately, ideally after the OPS-3 backup is in place. Confirm afterwards that /privacy and /terms return 200. Write down who deploys and how.	S
OPS-9	MEDIUM	Every enquiry is also emailed to a third-party mailbox that is hard-coded in source Owner Visitor PII and B2B and cruise enquiry details, such as company names and volumes, will go to an external company on every enquiry. The address cannot be changed without a code change and redeploy.	The owner should confirm in writing that this sharing is intended. If it stays, move the CC list to an environment variable such as ENQUIRY_CC_EMAILS, state clearly in the privacy page who receives enquiries, and consider excluding partner and B2B enquiries.	S
OPS-10	MEDIUM	A production deploy with no DATABASE_URL would run on in-memory PGLite while showing visitors success If the production DATABASE_URL is blanked, rotated badly or removed, the site keeps working and shows 'Received.', but enquiries and accounts go into a throwaway per-instance database. Only the Resend email would survive.	Call the guard in createSql() whenever isDeployedRuntime() is true, so production throws instead of falling back. Add a startup log line stating the database backend.	S

OPS-11	MEDIUM	The newsletter is a list that staff cannot see and that cannot be used Owner The site promises a newsletter that has no way to send, no way to unsubscribe, and no way for staff to read the list. Anyone can subscribe a third party's address with no consent check. The privacy text does not match what is stored.	Either remove the form until a newsletter process exists, or add an admin list with CSV export, a consent timestamp, double opt-in, and a tokenised unsubscribe link. Make the privacy page match what is stored.	M
OPS-12	MEDIUM	The dormant booking funnel is live at production URLs and can still write to the database Anyone with the URL can create hold rows that appear as 'Holds / pending' on the admin dashboard and in the Bookings screen. A visitor reaching it sees a hold flow that ends in 'quote only' or 'the operations desk will invoice you'. This contradicts the firm product rule.	Gate the funnel server-side behind a BOOKING_ENABLED flag that defaults to off, so createHold throws and the routes show an enquiry form. Add noindex or robots Disallow for /booking, /checkout and /account. Do not add a scheduler for hold expiry.	S
OPS-14	MEDIUM	pg pools have no error handler and no timeouts, which is a risk with Neon scale-to-zero Intermittent 500s or dropped requests after idle periods, and long hangs if the database is slow or unreachable.	Add pool.on('error', log.error), connectionTimeoutMillis, idleTimeoutMillis and a statement timeout to both pools, and test an idle-then-request cycle against a Neon branch.	S
OPS-15	MEDIUM	Staff cannot honour privacy deletion requests or manage content from the system Owner A deletion request means hand-written SQL in the Neon console. Any change to tours, itineraries, journal posts or photos needs a developer plus a redeploy. The owner decision on content management is still open.	First add a small 'data request' tool for admins to find, export and delete or anonymise an email's enquiries and subscriber rows, with an audit entry. Keep content in the repo until the owner decides whether a CMS is needed. Delete or finish the unused storage helper.	M
OPS-13	LOW	Internal and driver error messages can reach visitors A pg error (connection refused, timeout, a SQL error naming a table or column) would be shown to a visitor. That is poor presentation and leaks internals. Combined with OPS-5, the visitor sees technical text where a phone number would help.	Map thrown errors to a short public message and log the real error with log.error. Only pass through errors the code throws deliberately, such as validation and rate-limit messages.	S
OPS-16	LOW	There is no hold-expiry scheduler, but this is not a defect while booking is out of scope None while booking stays dormant. The scheduler question only matters if online holds are ever enabled.	Do not build a scheduler now. If holds are ever re-enabled, call expireHolds inside a transaction on every read path or run the cron endpoint from an external scheduler, because Vercel Hobby crons are daily only (plan not verified). Remove the stale CRON_SECRET entry from the docs if the route is retired.	S
OPS-17	LOW	Migration safety nets are thin A bad migration or schema drift is caught only at production deploy time, where it fails the build safely but late. Schema changes must stay backward compatible with the code currently serving.	Add a CI step that applies migrations 0001 to 000N to a fresh PGLite or Postgres. Store a checksum per migration. Prefer expand-then-contract changes. Use the unpooled URL and an advisory lock for migrations.	M

OPS-18	LOW	Environment documentation does not match reality, and Preview deployments run unconfigured A future developer or the owner may misconfigure production, or rely on a Preview URL as if it were safe. Anyone opening a public preview URL can claim SUPER_ADMIN there, with throwaway data only.	Correct the README and .env.example. Add a one-page production checklist listing the six required variables. Turn on Vercel Deployment Protection for Previews, or set an explicit preview env. Remove the Grok leftovers from the active code paths when convenient.	S
OPS-19	LOW	There are no automated tests for the revenue path, RBAC or the rate limiter Regressions in the enquiry flow, which already needed a fix for a null currentTarget crash, are caught only in production.	Add DB-backed tests on PGLite for submitEnquiry (success, database failure, Resend failure), the admin RBAC matrix, and the rate limiter.	M
OPS-20	LOW	Copy and wiring slips around enquiries and privacy Owner Visitors see jargon, and the receipt gives no way to quote a reference or reach the desk by phone. The privacy page is slightly inaccurate. The reply-time claim is unverifiable.	Use the friendly ENQUIRY_TYPE_LABELS in the receipt. Show the reference in the success message and receipt, and include the approved phone and WhatsApp numbers. Align the privacy page with real behaviour, which needs the owner or a lawyer. Track a replied_at timestamp so the 24-hour claim can be checked.	S
OPS-21	LOW	Every tour page view runs a database query for reviews that cannot exist Each tour view can wake the scale-to-zero database and spend free-tier compute hours for a feature that has no data. A cold start also slows the page's reviews section.	Hide the reviews fetch behind the same BOOKING_ENABLED flag, or skip it until any approved review exists.	S

Security, authentication and admin access

17 findings ·  partial

The code-level security model is better than most sites this size: all 12 per-user and admin server functions reject an anonymous caller (tested on the dev server), every admin function re-checks the role in the database, SQL is parameterised, inputs go through Zod, and webhooks verify signatures and are idempotent. npm audit reports 0 vulnerabilities, and no secret has ever been committed. The baseline audit's biggest auth worry, production being mistaken for preview, is fixed on the live site, though only through one environment variable. The real exposure is operational: the admin account is probably still unclaimed behind open, unverified sign-up; the live site loads a third-party grok.com script on every page including /login and /admin; no browser security headers beyond HSTS are set; password reset does not work; and rate limiting only lasts as long as one warm serverless instance. Note that the live deployment is older than the working tree (no /privacy, /terms or /cookies; no cron route), so some code findings apply only once the current tree is deployed.

ID	SEVERITY	FINDING	RECOMMENDATION	EFFORT
----	----------	---------	----------------	--------

SEC-1	MEDIUM verified, adjusted	SUPER_ADMIN can be pre-empted: sign-up is open and unverified, the claim is gated only by an email string, and the admin is probably still unclaimed Owner If the address is guessable (the public info@tourismislife.com is an obvious candidate) a stranger can become permanent SUPER_ADMIN. That gives access to every enquiry (names, emails, phones, messages) and the ability to create staff and moderate reviews. The owner would then be locked out of the claim. Recovery would need direct database surgery.	Today: the owner registers with the bootstrap address and claims SUPER_ADMIN, then confirms staff_profiles and bootstrap_lock each have one row. Before any more staff are invited: wire Resend email verification and require it for the bootstrap claim, or add a Better Auth databaseHooks.user.create.before hook that rejects registration of the bootstrap address by anyone but a verified flow. Better still, make the claim require a one-time BOOTSTRAP_TOKEN secret, or insert the first SUPER_ADMIN row by script and delete the web claim path.	S
SEC-2	MEDIUM verified, adjusted	Third-party script from grok.com is injected into every page on the live site, including /login, /register and /admin Arbitrary JavaScript from a vendor the owner has no contract with runs with full DOM access on the pages where passwords and the admin console live. A compromise or silent change of that file could steal credentials or customer data. Each page view also sends visitor IP and referrer to grok.com, which no privacy notice discloses.	Delete the head-injection middleware (server/middleware/grok-pwa.ts, serverDir in vite.config.ts) or at least stop emitting GROK_EXTENSIONS_SCRIPT_SRC. Keep only a first-party manifest. Rebuild, redeploy and confirm with a curl of /login that no grok.com script remains.	S
SEC-3	MEDIUM	No browser security headers beyond HSTS: no CSP, clickjacking protection, nosniff, referrer or permissions policy /login, /register and /admin (including the one-click 'Claim SUPER_ADMIN' button) can be framed for clickjacking. There is no defence in depth if any XSS or malicious script ever lands (see SEC-2). Referer behaviour is browser-default only.	Add headers through Nitro routeRules in the nitro() options in vite.config.ts, or vercel.json: X-Content-Type-Options: nosniff, Referrer-Policy: strict-origin-when-cross-origin, X-Frame-Options: DENY plus CSP frame-ancestors 'none', and a restrictive Permissions-Policy. Then add a CSP, starting Report-Only. It needs nonces or hashes for the TanStack stream-barrier script, the theme bootstrap and JSON-LD, plus an allowance for fonts.googleapis.com and fonts.gstatic.com. Add includeSubDomains to HSTS only after checking subdomains.	M
SEC-4	MEDIUM	Password reset and email verification are not wired, yet the UI tells users a reset link will follow No one can recover a forgotten password, and that includes the sole SUPER_ADMIN. A lost admin password is a permanent lockout fixable only in the database. The page misleads visitors, and accounts are never email-verified (feeds SEC-1).	Implement sendResetPassword and sendVerificationEmail in the Better Auth config via the existing Resend sender. Switch the client to authClient.requestPasswordReset, show real errors, and consider requireEmailVerification: true.	M

SEC-5	MEDIUM	Rate limiting resets per serverless instance and public forms have no bot protection, so the enquiry endpoint can be used as an email relay and spam source Owner A scripted attacker can flood the desk inbox, burn Resend quota and make the company domain send attacker-worded email to arbitrary third parties (reputation and deliverability damage). Sign-in brute force is throttled only per instance.	Add Cloudflare Turnstile (or at least a honeypot plus minimum-time check) to enquiry, newsletter and sign-up forms. Move the limiter to a shared store (Upstash, or a Postgres table, or Vercel firewall rules). Configure Better Auth rateLimit with a shared storage. Make the auto-reply a fixed template that does not echo submitted text, and add double opt-in to the newsletter.	M
SEC-6	MEDIUM	Role hierarchy hole: an ADMIN can demote a SUPER_ADMIN, the last-super check is racy, and STAFF/CONTENT roles all see all customer PII A non-super ADMIN can remove or replace a SUPER_ADMIN whenever two exist, and any staff role can read all bookings and enquiries (names, emails, phones). Least privilege is not enforced.	Reject any role change where the target is SUPER_ADMIN unless the actor is SUPER_ADMIN, and run the count and update in one transaction with a lock. Verify the target exists. Raise the minimum role for PII-bearing reads (bookings and enquiries to BOOKING_MANAGER or above) and use CONTENT_MANAGER only for content and review moderation.	S
SEC-7	LOW	The production-versus-preview guard fails open and rests on a single environment variable Not exploitable today. If BETTER_AUTH_URL is ever dropped or renamed (domain move, env cleanup), the live site silently flips to permissive preview mode (demo payments settle bookings without payment, cron endpoint opens, Grok OAuth returns). The BOOTSTRAP_ADMIN_EMAIL check would still hold.	Invert the default: treat the process as deployed unless affirmatively local (NODE_ENV !== 'production' in vite dev, or VERCEL_ENV in preview/development). Alternatively enable 'Automatically expose System Environment Variables' in Vercel, or require an explicit APP_ENV=production variable and fail startup if absent. Add a startup assertion log line and a smoke test for the callback 404.	S
SEC-8	LOW	Grok-platform auth code ships to production, and a shared OAuth client secret is committed in source Dead third-party trust paths enlarge the account-takeover surface for no benefit, and a shared secret in source is a hygiene problem if the repo is ever made public. Low real exploitability today.	For a Vercel-only deployment, remove gatelidentitySessions, the genericOAuth and preview-client code and preview.ts, drop bearer() unless needed, and trim trustedOrigins to the production origin. If the Grok parts must stay, rotate or deregister the shared secret and bind dev to 127.0.0.1.	M
SEC-9	LOW	Dormant booking and payment server functions are still callable by anyone, and unauthenticated calls trigger database writes Product rule says online booking is dormant, yet an attacker who knows the endpoints can create holds that consume seat capacity, fill bookings and availability, and generate database load (Neon compute cost). No payment bypass exists while the deployment is correctly classified.	Add an explicit ONLINE_BOOKING_ENABLED flag (default false) checked at the top of every booking and payment server function so they throw before touching the database. Keep the code for later. This also removes the SEC-7 dependency for demo settlement.	S
SEC-10	LOW	Login and register forms ignore Better Auth errors and always redirect to /account A wrong password or weak password shows no message; the user lands on /account signed out. Duplicate-email and verification errors are silently swallowed, which confuses legitimate users and hides attack signals.	Destructure { error } from the call, show error.message, and only redirect on success, or set fetchOptions: { throw: true } on the client.	S

SEC-11	LOW	DMARC is in monitor-only mode (p=none) with no reporting address Owner Anyone can send mail that appears to come from info@tourismislife.com and receiving servers are not told to reject it. This is a phishing risk to customers and partners of a travel business that takes enquiries by email.	Add a rua reporting mailbox, watch reports for a few weeks to confirm Microsoft 365, SiteGround and Resend all align, then move to p=quarantine and later p=reject. Owner or DNS host must make the change.	S
SEC-12	LOW	No security regression gate is actually active: CI is untracked and the live build lags the repo Hardening done in the working tree is not live, and nothing automatically catches a regression such as a dropped admin check or a new vulnerable dependency. Loss of the uncommitted work is also possible.	Commit and push the work including .github/, add 'permissions: contents: read', pin actions by SHA, add 'npm audit --omit=dev --audit-level=high', enable Dependabot, and redeploy so production matches the reviewed code.	S
SEC-13	LOW	Internal image licence ledger is publicly served and flags 33 images as unverified Owner The site publicly documents its own unverified image rights, which hands a copyright claimant evidence. It is also an information leak of internal editorial notes.	Move the ledger out of public/ (for example to a docs or data folder bundled only for the image-credits page) and resolve or replace the unverified images.	S
SEC-14	LOW	Local .env.local points at the production Neon branch Owner Running npm run preview or the migrate script locally can read or write production data under permissive preview rules, against the project rule 'never create users, staff roles or bookings in production'.	Create a separate Neon development branch (neon.ts already supports branch TTLs), point .env.local at it, and keep production credentials only in Vercel.	S
SEC-15	LOW	JSON-LD helper does not escape '<' in embedded JSON If a future page passes user-controlled text (for example a review or search term) into JsonLd, a value containing </script> would break out of the script tag and run script.	Serialise with JSON.stringify(data).replace(/</g, '\\u003c') (and U+2028/9) inside JsonLd so the helper is safe by construction.	S
SEC-16	LOW	Stripe adapter treats checkout.session.completed as paid even when payment_status is not 'paid' Before payments are ever enabled, a delayed-settlement payment method could confirm a booking before money arrives, and per-person pricing would be wrong.	Require payment_status === 'paid' (or handle checkout.session.async_payment_succeeded) and define the pricing unit before enabling any live provider. This is not needed while the enquiry-led model stands.	S
SEC-17	LOW	Every enquiry (with visitor PII) is emailed to an external partner mailbox Owner Visitor personal data goes to a third-party company. If the privacy notice does not say so, that is a data-protection exposure.	Owner confirms the partner arrangement is intended, and the privacy notice names the recipient category. Consider sending the partner only a notification or limited fields.	S

Dormant commerce, accounts and vouchers

16 findings · partial

The hold, checkout and webhook engine is real and carefully built, and money cannot move today: no tour has a priceCents, the Stripe and Moneroo webhooks return 503 without keys and reject quote-only bookings, and demo settlement is off whenever the

runtime is classed as deployed. But the commerce flow is neither dormant nor unexposed. 16 of 22 tours send visitors from "Select dates" into /booking/\$slug, and for those tours that is the only call to action. A visitor can hold seats and type name, email and phone into a payment screen that cannot complete and alerts nobody, while the tour FAQs, booking, login and checkout copy promise holds, payments and vouchers and the Terms page says the site takes no online payments. The demo-payment gate fails open (it is off only if production carries VERCEL_ENV=production or BETTER_AUTH_URL), and the account area is an 8-tab commerce portal where 5 tabs can never hold data, behind open email sign-up with no verification in front of an unclaimed one-time SUPER_ADMIN bootstrap. Vehicle rental, hospitality, cruise and quote-only tours already follow the enquiry-led rule correctly and are the model to copy.

ID	SEVERITY	FINDING	RECOMMENDATION	EFFORT
BK-1	HIGH verified, adjusted	The dormant hold/checkout flow is the primary call to action on 16 of 22 tour pages, contradicting firm product rule 1 73% of the catalogue sends a visitor into a seat-hold and payment flow the business has said must not exist, instead of the enquiry the business actually fulfils. Those tours have no enquiry button on the page at all. The flow cannot be completed (see BK-3), so the main conversion path leaks leads. It also contradicts the Terms and the tours-excursions copy (BK-2).	Make the enquiry the CTA for every tour. Introduce one BOOKING_ENABLED constant (default false) and derive the UI from it: render EnquiryForm and 'Request a quote' for all tours, replace 'Check availability' with 'Request a quote' or 'Send an enquiry', remove the 'Self-serve bookable' filter and bookable-first sort, and give the homepage featured list an explicit slug list instead of filter(bookable). Fastest interim step (S): set bookable:false on the 16 tours and fix the featured selection; createHoldTx then refuses (booking-engine.ts:83). That alone is not a kill switch (see BK-4), so pair it with the server-side guard.	M
BK-3	HIGH verified	In production the journey dead-ends at a payment screen that cannot work, and the visitor's contact details are stored with no alert to the desk A real visitor who follows the main CTA gives name, email and phone, reaches a button labelled 'test settlement', then sees a failure. The desk is never told, so the lead is lost and personal data sits in the bookings table with no owner.	Close the flow (BK-1, BK-4). If any part stays reachable, make the checkout UI honour demoAllowed and quoteOnly (hide demo buttons, show 'The desk will send a written quote' plus an enquiry form), and call releaseAndMark before telling the visitor a hold was released. Convert any captured details into a normal enquiry (submitEnquiry) so the desk is emailed.	S
BK-2	MEDIUM verified	Public copy promises holds, payments, vouchers and accounts that the site does not offer, and conflicts with the Terms page Visitors are told a payment-and-voucher process exists, while Terms says the opposite. That is a consumer-trust and legal inconsistency on every tour page and a firm-rule breach (enquiry language only, never invent process).	Rewrite baseFaqs to enquiry language (for example: how enquiries become written quotes, how departures are confirmed by the desk), drop voucher wording from meetingPoint, and fix the booking, login and register helper text. Have the owner approve the wording. When BOOKING_ENABLED is off, none of the booking and checkout strings should be reachable.	S

BK-4	MEDIUM	Hiding the UI would not disable the booking and payment server functions; there is no kill switch Even after the pages are removed, anyone can script holds, so bookings and availability rows for arbitrary dates can pollute the database and temporarily lock a date. If the runtime is ever misclassified (BK-5), the same endpoints settle demo bookings and send confirmation emails.	Add one server-side guard (BOOKING_ENABLED, default off) at the top of every function above and at the webhook routes (return 404 or 503 when off). Also add a route-level beforeLoad redirect for /booking, /checkout and the commerce account tabs. Cap travelDate (for example 24 months), and rate-limit getAvailability. Cover with a test that fails if a new commerce server function lacks the guard.	S
BK-5	MEDIUM verified, adjusted	Demo-payment, bootstrap and cron gating fails open: production is safe only if it carries a positive 'production' signal Owner One missing or misspelt environment variable silently re-opens fake 'confirmed' bookings and vouchers, outbound emails from the real domain to arbitrary addresses, and an open admin bootstrap. On a host without DATABASE_URL the app also falls back to ephemeral PGLite, so enquiries can vanish. Public pages do not use auth, so nothing would visibly break to reveal it. Preview deployments carry the same permissiveness, and if Vercel Preview env vars include the production DATABASE_URL (not checked) they can write to the live database.	Invert the default. Allow demo payments only when explicit opt-in DEMO_PAYMENTS=1 is set and the host is local (NODE_ENV !== 'production' and DATABASE_URL absent or loopback). Call productionRequiresDatabase() at startup, and extend the db.ts guard to VERCEL or NODE_ENV=production. Add unit tests for each row of the matrix. In Vercel, confirm Preview does not hold the production DATABASE_URL and that Deployment Protection is on.	S
BK-6	MEDIUM verified, adjusted	Open email sign-up with no verification sits in front of the unclaimed one-time SUPER_ADMIN bootstrap Owner If the bootstrap address is guessable (for example the public info@ address) and still unclaimed, whoever registers it first can take permanent SUPER_ADMIN, with access to every enquiry (customer personal data), bookings and role management.	Owner should claim SUPER_ADMIN now, from the real address, before anything else is shared. After that, close public sign-up (disableSignUp driven by an env flag) or require verified email through Resend before an account can use the bootstrap. Staff then need an invite or temporary-enable path. Since enquiries need no account, nothing visitor-facing depends on open sign-up.	S
BK-7	MEDIUM	Sign-in and register forms swallow failures; password reset cannot work but reports success Anyone with an account cannot recover a lost password and is told a link is coming. Failed sign-ins look like a broken page. Internal setup details are shown to visitors.	If accounts stay (staff at minimum): read result.error and show it, use authClient.requestPasswordReset with a Resend-backed sendResetPassword, and reword the public text. If accounts are removed for visitors (BK-8), restrict /login to staff and drop the forgot and reset pages from the public surface.	S

BK-8	MEDIUM	The account area is a commerce portal that is incoherent with an enquiry-only site: 5 of 8 tabs can never contain data Owner A visitor who creates an account sees a booking, payment and voucher portal for a business that takes no bookings or payments. It stores personal data without delivering value and invites support questions.	Pick one: (1) staff-only auth. Keep /login for the operations desk, remove public registration after SUPER_ADMIN is claimed, and replace 'Save tour' with the existing localStorage favourites pattern, so visitors never need an account. (2) If visitor accounts are wanted, cut the portal to Saved tours and My enquiries and hide Bookings, Payments, Vouchers, Reviews behind BOOKING_ENABLED. Either way, hide the public reviews section until a real review source exists.	M
BK-9	MEDIUM	Booking and account pages are indexable, and unknown slugs return HTTP 200 Search results can land people on a 'Hold seats for 15 minutes' page; auth pages and soft-404s dilute the index.	Pass noindex,nofollow to pageHead for /booking/*, /login, /register, /forgot-password, /reset-password and give /booking/\$slug/confirmed a head. Add Disallow rules for /booking/, /checkout/, /account/, /admin/ and /api/ in robots.txt. Return real 404s for unknown tour and vehicle ids (check production behaviour too).	S
BK-10	MEDIUM	Privacy and cookie pages do not describe what the booking flow collects and stores Owner Personal data is collected by a flow the policy does not mention, with no retention rule. This is the likeliest legal exposure from leaving the flow reachable.	Closing the flow (BK-1, BK-4) removes most of this. In the meantime add a retention purge for HOLD, PENDING_PAYMENT and EXPIRED rows, and have a lawyer-reviewed policy cover any data the site truly collects. If commerce is ever enabled, update privacy, cookies and Terms first.	S
BK-11	MEDIUM	Vehicle rental shows daily rates and 'Available / Limited' badges with no recorded source Owner If the rates or availability are not owner-supplied, the site invents prices and implies live availability on the one flow that is otherwise correct and enquiry-led.	Owner to confirm the source of each rate and of the Available/Limited flags. If unconfirmed, replace with 'Rate on request' and remove availability badges; keep the enquiry flow as is. Guard the ?? 0 fallback.	S
BK-12	MEDIUM	Tour ratings and group sizes on the 16 bookable tours repeat across tours and have no recorded source Owner Identical ratings across unrelated tours look like a site-wide figure applied per tour, and the 'public catalogue' wording cannot be checked. This breaches 'never invent ratings or reviews' if unsourced, and reviews feed nothing in an enquiry-only site.	Owner to supply the source for each rating and group size; otherwise remove the rating line and show 'On request' for group size, as is already done for 0/0. Keep the public reviews block hidden until real reviews can arrive (BK-8).	S

BK-13**MEDIUM****Decision needed: remove, flag, or keep the dormant commerce code (options with facts)** Owner

The choice sets the maintenance cost, the attack surface and how fast payments could be added later.

(a) Remove: delete the routes, engine, adapters and commerce server functions, keep tables (never drop production tables without a data plan), and cut tests accordingly. Smallest attack surface and no mis-flip risk, but it discards tested logic, ops.ts must be split carefully, effort L (about 1 to 2 days), reversible only from git. (b) Feature flag, recommended now: BOOKING_ENABLED (server env plus a build-time VITE_ constant), default off, enforced in the UI, in route beforeLoad redirects to /contact, and in the first line of every commerce server function and webhook route (BK-1, BK-4), with explicit DEMO_PAYMENTS opt-in (BK-5) and a test that fails if the flag is bypassed. Effort M (about 1 day), reversible, keeps the code but the dormant code must keep compiling and be tested (BK-15). Revisit (a) if no payment plan exists within roughly 6 to 12 months. (d) Enquiry-led improvements, which fit the rule and the Terms: an enquiry form on every tour page (EnquiryForm already exists), a clear reply time, richer enquiry statuses than open/closed (adminSetEnquiryStatus allows only those two), written quote by email, payment arranged offline by invoice with the desk recording it. Do not enable online booking or payments as part of this clean-up.

M

BK-14	LOW	What taking payments safely would require later (facts for the owner; not recommended now) Owner	Checklist the owner and a lawyer or accountant would need to settle: (1) provider eligibility: Stripe's list of supported business countries must be checked for Sierra Leone (NOT VERIFIED), and Moneroo (or another aggregator) must confirm that Orange Money and Afrimoney Sierra Leone, SLE and USD settlement and a local payout account are available to this merchant; each needs a legal entity, registration documents, KYC and a bank account. (2) Webhooks: live and test endpoints and secrets in env, signature and replay tests, sandbox end-to-end per provider. (3) Currency and FX: price list in a stated currency, settlement currency, Bank of Sierra Leone rules. (4) Tax: GST treatment of tour services, any tourism levies, invoicing and receipts, confirmed with an accountant or the NRA. (5) Legal pages: Terms rewrite, refund and cancellation policy, privacy and cookies updated for payment processors and booking data, supplier cancellation terms, chargeback handling. (6) Published, owner-approved prices with per-person or per-group rules (today none exist). (7) Engineering: guest-count pricing, payment_status handling, refund and cancel admin tools with provider refund API and events, confirmation email and staff alert on the webhook path, admin availability editor, scheduled hold expiry (Vercel Hobby cron is daily only), Upstash for distributed rate limiting, DB integration tests, monitoring, backups and a reconciliation report. (8) Operations: who owns disputes, refunds and the support inbox.	L
BK-15	LOW	The DB-backed booking engine has no automated tests, so keeping it dormant (option b) leaves unproven code behind a flag If the flag is flipped later, the 'no double booking' and settlement guarantees rest on unproven code.	If option (b) is chosen, add PGLite-backed tests for hold, capacity, concurrent holds, expiry, duplicate webhook and settle-once, and a test asserting the flag disables every entry point. If option (a), drop the dead tests with the code.	M

BK-16

LOW

README and env example still advertise booking, checkout, vouchers and demo mode as features

A new developer or deploy reads the README as the intended product and may enable payments or rely on demo mode in an unsafe place.

Update README and .env.example to say the commerce flow is disabled by BOOKING_ENABLED and that demo payments are local-only. Note that CLAUDE.md is the source of truth.

S

SEO and discoverability

20 findings ·  partial

The on-page SEO foundation is better than most sites at this stage. Every indexable route uses pageHead() with one title, description and self-referencing absolute canonical, pages are server-rendered with real content, there are no broken internal links, and 22 TouristTrip, 15 TouristDestination and 4 Article JSON-LD blocks exist. Discoverability is held back by five problems, all confirmed in the current code and on the dev server. The production head injector overwrites every page's share metadata with one generic card. The hand-written sitemap omits 70 of about 100 indexable URLs, including all 22 tour pages. Invalid catalogue slugs return HTTP 200 as soft 404s. Auth, booking and confirmation pages are indexable. There is no analytics or Search Console. A canonical-host question (apex in the code, www in CLAUDE.md) also needs an owner decision. Live-site behaviour, Google Business Profile and Core Web Vitals could not be checked from the repo.

ID	SEVERITY	FINDING	RECOMMENDATION	EFFORT
SEO-1	MEDIUM verified, adjusted	Production head injector replaces every page's Open Graph and Twitter tags with one generic card Every shared tour, destination or journal link on WhatsApp, Facebook, X and LinkedIn shows the same title, the same tagline and the same image. The per-page metadata in pageHead() is silently discarded for social previews. This is the main way a travel brand gets clicks from shares.	Stop the injector from stripping tags the page already supplies. Either remove the strip step for share metas, or drop grokPwaPlugin and server/middleware/grok-pwa.ts and keep only the PWA tags the site needs. Then extend pageHead() to emit og:image:width, og:image:height, og:image:alt and twitter:site (@tourismislife), and accept a per-page absolute image so tour and destination pages share their own photograph. Confirm with curl against a preview build that og:title, og:url and og:image differ per route.	M
SEO-2	MEDIUM verified, adjusted	Hand-written sitemap lists 30 URLs and omits 70 of about 100 indexable pages, including every tour The commercial pages (tours, destinations, services) are the ones a search engine is not told about. They are found only through internal links, which slows indexing and gives Search Console no sitemap-vs-indexed comparison. A hand-edited list will also drift every time catalog.ts changes.	Generate the sitemap from the single sources of truth (catalog.ts tours, destinations, circuits, services, articles; cruise.ts; vehicle-rental.ts) via a Nitro or TanStack server route, or a build step that writes public/sitemap.xml. Add <lastmod> only from a real date, for example article.date. Exclude noindex, auth and booking pages, plus /tours/search. Add a unit test that compares the generated list with the routes whose head says index.	M
SEO-3	MEDIUM	Canonical host is hard-coded to the apex domain while project docs say the live site is www Owner If the live site redirects apex to www, every canonical, sitemap URL, breadcrumb and schema URL points at a redirecting address. Google usually recovers, but the mixed signal slows consolidation and splits reporting in Search Console. This escalates to high if the redirect direction contradicts the canonical.	The owner confirms the primary host in Vercel domain settings. Then change the single SITE.website constant, preferably reading it from one env var, so canonicals, sitemap, robots and JSON-LD agree. Make the non-primary host and http 301/308 to the primary one. Do not edit DNS; that is a Vercel domain setting.	S

SEO-4	MEDIUM	Unknown catalogue URLs return HTTP 200 with an empty page, an index,follow tag and a self-canonical (soft 404) Any mistyped or stale link, or a case variant, becomes an indexable 200 page with no content. Crawlers classify these as soft 404s, which wastes crawl budget and can pollute index coverage reports. Only the client-side render shows the 404 UI.	Move the existence check into a loader or beforeLoad (the pattern already used in src/routes/hospitality/stays/\$slug.tsx:7-12) so SSR returns a real 404 status. Return a not-found head with noindex for those cases. Lower-case slugs or redirect case variants, and validate that the circuit or category segment matches the record.	M
SEO-5	MEDIUM	Auth, booking, confirmation and form-result pages are indexable and some carry conflicting canonicals Sign-in and password-reset pages compete in results with no value, and transactional steps are exposed to indexing. The two canonicals on the confirmation page are an invalid signal. The 'Hold seats' description also contradicts the enquiry-only product rule, and linking tour pages to the dormant booking flow sits outside this audit's scope.	Pass 'noindex,nofollow' to pageHead() for login, register, forgot-password, reset-password, booking/* (including confirmed), vehicle-rental book and confirmation, and checkout children. Add noindex to /tours/search or drop it from the sitemap. Give /coming-soon a pageHead() or fold it away. Fix the parent/child head merge so a page emits one canonical. Product-rule note for the owner: the dormant booking links on tour pages should be removed or kept hidden per the no-online-booking rule.	S
SEO-6	MEDIUM	Each journal article is reachable at two URLs, both indexable and self-canonical Link equity and indexing signals are split across two URLs per article, and Google must choose a canonical itself. The JSON-LD URL disagrees with the page's own canonical on half the URLs.	Pick one scheme, preferably /journal/<slug>. Make the other route a 301 redirect (or give it a canonical to the chosen URL) and link only the chosen form from every page.	S
SEO-7	MEDIUM	Tour and destination pages share identical titles, and most titles carry no search-intent keyword Duplicate titles make the tour page and the matching destination page compete and look alike in results. Generic titles miss searches such as 'Banana Island day trip Freetown' or 'Sierra Leone shore excursions'.	Format titles by page type using facts already in the catalogue, for example '<Tour> · <duration> from Freetown, Sierra Leone' for tours and '<Place> travel guide, Sierra Leone' for destinations. Add 'Sierra Leone' to the hub-page titles. Do not add claims that are not in the data (prices, ratings, 'best').	S
SEO-8	MEDIUM	JSON-LD has invalid relative image URLs, a hard-coded touristType, and an empty itinerary Google requires absolute image URLs, so image eligibility is lost on tour, destination and article markup. The fixed touristType is an unsupported claim. The entity graph is not connected, so the Organization is not reused by the trips it provides.	Prefix SITE.website to every image in tourJsonLd, articleJsonLd and the destination block. Drop touristType or derive it from tour.category. Build itinerary from tour.itinerary days or remove it. Give the Organization an @id on the homepage and reference it from provider and publisher. Emit Organization once, on the homepage only. Validate with the Rich Results Test after the change.	S

SEO-10	MEDIUM verified, adjusted	No analytics, Search Console or Bing Webmaster verification anywhere in the site Owner There is no way to see queries, impressions, index coverage, soft-404s, sitemap processing or which tours people read. SEO work cannot be measured or prioritised, and indexing problems stay invisible.	The owner creates a Google Search Console property for the primary host (SEO-3) and a Bing Webmaster property. Verify with an HTML-file or meta-tag method rather than DNS, since DNS is off-limits in this project. Submit the generated sitemap. For visitor analytics, choose a cookieless, privacy-first tool and update /cookies and /privacy to match before it goes live.	S
SEO-11	MEDIUM	Four cruise sub-pages are orphaned and thin, five journal categories are empty, and the copy reads as internal notes Owner Orphaned pages cannot be discovered by users or crawlers except via the sitemap, which does not list them either. Thin or empty indexable pages add near-duplicate noise and look unfinished. Editor-facing wording is public.	Either link the four cruise pages from /cruise and the nav and add real content from the cruise handling documents, or fold them into /cruise and redirect. Set noindex on empty journal categories until they have posts (or hide the category chips). Replace editor-facing phrases with visitor-facing wording.	M
SEO-14	MEDIUM	Share image setup is inconsistent and unrecorded: two different files, one share image site-wide Owner What a visitor sees when a link is shared depends on which code path wins (see SEO-1). The /og.jpg scene looks generated or illustrative rather than real Sierra Leone photography, which conflicts with the images rule, and its origin is undocumented. Per-page images are a missed chance, since every tour already has a real photograph.	The owner decides on one brand share card and records its provenance in image-sources.json, or replaces it with a real Sierra Leone photograph plus the logo. Keep one file and one reference. Add per-page images for tours and destinations from their existing catalogue photos once SEO-1 is fixed.	S
SEO-15	MEDIUM	Third-party grok.com script and duplicate manifest/apple-touch-icon tags are injected into every page head An unvetted external script loads on every production page, which adds a third-party request and a dependency on grok.com. It sits awkwardly with the cookies page statement that no tracking tools run. Duplicate manifests with different theme and background colours (#000000 vs brand green) give inconsistent install behaviour.	Remove the Grok head injection (see SEO-1) so the site controls its own head. Keep only the app's manifest and icons, and confirm the final head with curl.	S
SEO-18	MEDIUM	Images are served at full size with no srcset or modern formats Large unscaled images and many preloads put pressure on LCP and CLS on mobile connections in West Africa, which affects page-experience signals and bounce. The effect size is NOT VERIFIED without a real measurement.	Generate responsive widths (for example 480, 960, 1600) with srcset/sizes, convert to AVIF or WebP, set width and height on images, and limit preloads to the first hero image. Self-host the two fonts. Measure with Lighthouse and the Search Console Core Web Vitals report once SEO-10 exists.	M

SEO-9	LOW	Structured-data coverage is partial: no BreadcrumbList on hubs, no Service or ItemList markup Hub and service pages show less structured context. Breadcrumb trails in results are inconsistent across the site. FAQPage rich results are now limited to a few authoritative site types, so the FAQ gap has little practical weight.	Add BreadcrumbList through a shared helper on all hub, service, cruise, about and journal pages. Add Service (provider linked by @id, areaServed from SITE) for the services and cruise pages. Add ItemList to /tours and country pages. Treat FAQPage as optional and low priority. Do not add Offer, AggregateRating or priceRange without published source data.	M
SEO-12	LOW	Meta descriptions are inconsistent: some too long, some too short, several use internal wording Weak or truncated snippets reduce click-through. The 'public site' wording reveals the migration source rather than describing the page to a visitor.	Write a 120 to 155 character description per page type. Truncate at a sentence or word boundary, not mid-text. Use only facts already in the catalogue.	S
SEO-13	LOW	No French or hreflang support although Guinea is a French-speaking market Owner Guinea-bound searchers in French cannot find the site. This matters little today with one Guinea tour, but it becomes a limit if Guinea or West Africa content grows.	The owner decides if and when to commission a reviewed French translation (avoid raw machine output). When ready, use a path prefix such as /fr/, per-page hreflang pairs with x-default, and an og:locale. Until then, keep English only and avoid half-translated pages.	L
SEO-16	LOW	Local business data is incomplete for local and Google Business Profile use Owner Weaker match between website, schema and a Google Business Profile, and no hours or map for local searches in Freetown.	The owner supplies verified opening hours and a map or place link. Add contactPoint with both approved numbers, geo if confirmed, and clean sameAs URLs (canonical profile links). Keep the name, address and phone text identical on the site, in schema and in the Business Profile. Do not invent hours or coordinates.	S
SEO-17	LOW	Tour gallery alt text is too short to be useful, and some is duplicated Weaker image search visibility and accessibility on the pages that matter most. The 'editorial stand-in' labels in alt text are honest but read as disclaimers.	Rewrite gallery alt text to describe what is in each frame plus the place, using the curated alt field in image-sources.json, and make sure each is unique per page. Keep honest stand-in wording. Check the alt="" images on /about/sustainability are really decorative.	S
SEO-19	LOW	Homepage H1 contains all four rotating hero headlines and no brand or topic The main on-page heading search engines read is a run-together phrase with no business descriptor. It weakens topical relevance for the homepage, the highest-authority page.	Use a single stable H1 such as 'Tourism Is Life: tours and destination management in Sierra Leone' (visually styled or screen-reader text), and keep the rotating headlines as non-heading elements. Reduce /brochure to one H1.	S

SEO-20	LOW	404 page has a generic title, no helpful links, and robots.txt has no rules Visitors landing on a dead URL have no path onward except the shared header. Crawlers can request API endpoints. Neither is serious.	Make the three suggestions real links, give the 404 a title such as 'Page not found · Tourism Is Life' and a noindex tag. Add 'Disallow: /api/' to robots.txt. Leave /admin, /account and /checkout crawlable so their noindex tags can be seen.	S
--------	-----	--	--	---

Performance, accessibility and responsiveness

23 findings ·

 partial

Measured on a clean production build (npm run build:dev in a scratch copy, served with vite preview, Edge via Playwright, caches off, localhost so no real network latency). Strengths are real: route-level code splitting keeps per-page JS to 186-218 KB gzip, reduced-motion handling is correct (verified: zero animations and no rotation), landmarks and single h1 are present on all 9 pages sampled, and layout holds at 320-1920 px (1 overflow in 66 width x page combinations). The dominant problems are image delivery (34 MB of JPEG, no srcset or modern formats, the homepage fetches 6.4-9.4 MB before any scroll of which about 0.4 MB is visible), a build defect where the server HTML points at a stylesheet file the build does not emit (reproduced unstyled first paint and CLS 1.0 on desktop; live status NOT VERIFIED), and a cluster of keyboard and ARIA defects centred on the autoplaying carousels, an invisible skip link, 1.3-2.4:1 form-control borders and duplicate ids that leave inputs unnamed. No service worker exists, so there is no stale-content risk, but the platform's head injector adds a third-party grok.com script, duplicate manifest and icon links, and overwrites per-page Open Graph tags.

ID	SEVERITY	FINDING	RECOMMENDATION	EFFORT
PERF-1	HIGH verified	Server-rendered HTML links a stylesheet file the build does not emit (unstyled first paint, CLS 1.0 on desktop) If production has the same mismatch, every first visit paints unstyled HTML until about 200 KB of JS loads and hydrates, then the whole page jumps: CLS near 1.0 (10x over the 0.1 good threshold), a visible flash, much worse on slow mobile networks. CI cannot see it: <code>.github/workflows/ci.yml</code> only runs typecheck, lint, test and <code>build:dev</code> and never inspects the built HTML.	1) Verify production now: <code>curl the homepage</code> , extract the <code>/assets/styles-*.css</code> href and request it; it must return 200. 2) Make both environments emit identical CSS: pin Tailwind sources in <code>src/styles.css</code> (for example <code>@import 'tailwindcss' source(none)</code> plus an explicit <code>@source '../src'</code>) so build output, <code>node_modules</code> chunks and docs are not scanned in only one environment, then diff the two CSS files after a build. 3) Add a post-build script and CI step that extracts every <code>/assets/*</code> href from the built server HTML or bundle and fails if the file is missing from <code>.vercel/output/static</code> .	M

PERF-2	HIGH verified	Image delivery: 34 MB of full-size JPEG, no srcset or modern formats, 2400 px sources shown at 160-1300 px Mobile visitors on slow or metered connections in Sierra Leone and abroad pay 6-12 MB per homepage view; LCP and total load time are dominated by image bytes; low-end phones must decode dozens of 2400 px bitmaps.	Add a build step (sharp is already a devDependency) that emits 480/800/1200/1600 px WebP and AVIF variants, and one shared <code>Img</code> component that renders <code><picture></code> with <code>srcset</code> and <code>sizes</code> and keeps the JPEG as fallback; use 400-800 px variants for cards, thumbnails and the 36 px hero dots, and 1600 px for heroes. Keep <code>image-sources.json</code> provenance keyed to the original file. Target at most 1.5 MB of images for the first homepage viewport and about 3 MB for a full homepage scroll.	M
PERF-3	MEDIUM verified, adjusted	Homepage and tour pages fetch images the visitor cannot see (inactive hero slides, React-preloaded below-fold images, eager related-tour cards) The one image that matters (hero) competes with 5-8 MB of off-screen images on the same connection, delaying LCP and hydration on slow networks, and burning data for visitors who never scroll.	Add <code>loading=lazy</code> and <code>decoding=async</code> to every below-the-fold <code></code> (<code>index.tsx</code> forest band and experience tiles, related-tour cards, other route-level images); render hero slide 2+ only after first paint or after idle instead of relying on lazy inside the viewport; move the cruise background-image to an <code></code> with <code>loading=lazy</code>. Keep <code>fetchPriority=high</code> on slide 1 only. Re-measure the preload list in the built HTML: it should contain only the hero.	S
A11Y-1	MEDIUM	Skip link is invisible when focused (1x1 px) and 36 more tab stops precede the content Sighted keyboard users see no skip link and must tab through 36 header controls on every page (WCAG 2.4.7 focus visible, 2.4.1 bypass blocks in practice).	Delete the custom <code>.sr-only</code> block in <code>styles.css</code> (Tailwind v4 already provides <code>sr-only</code> and <code>not-sr-only</code>) or move it inside <code>@layer</code> utilities; re-test that the focused skip link measures about 150x40 px. Optionally give <code><main></code> <code>tabindex=-1</code> so focus lands there after activation.	S
A11Y-2	MEDIUM	Featured-tour/service carousels (StackedCardCarousel) hide focusable controls, do not pause when used, and drop keyboard focus every 4.2 s Keyboard and screen-reader users cannot reliably read the card details or reach the CTA before the card changes under them; focus on an invisible control violates WCAG 2.4.7; constant live announcements are noisy.	Pause autoplay on focus-within, hover and when flipped (<code>useSlideRotation</code> already supports <code>externalPause</code> but no caller uses it); mark the non-visible face inert or <code>aria-hidden</code>; keep the same DOM node across ticks (avoid key remount while focused); set <code>aria-live=off</code> while rotating and polite only when paused.	M

A11Y-3	MEDIUM	Form controls and focus ring fall below 3:1 non-text contrast on light themes and for field borders in every theme Low-vision users cannot reliably see where a field is or which one has focus on the light themes; the enquiry form is the site's single conversion path.	Darken <code>--color-line</code> for form borders in each theme (or add a dedicated <code>--color-field-border</code>) to reach at least 3:1 against both page and surface, and use a focus ring colour with at least 3:1 on the light themes (for example gold-ink or brand) while keeping gold on the dark themes. Re-measure with the oklab-aware method documented in CLAUDE.md.	S
PLAT-1	MEDIUM	Platform head injector adds a third-party grok.com script, duplicate manifest and touch-icon links, and overwrites per-page Open Graph tags on every document Owner Every visitor's browser contacts grok.com (privacy, third-party point of failure, no consent banner, contradicts the product's no-tracking posture); a Grok-branded banner may appear on a client's business site; iOS may pick the Grok placeholder as the home-screen icon; social shares of any page show the generic site title and description.	Decide with the owner whether the Grok banner and bridge are wanted on the live site; if not, remove <code>server/middleware/grok-pwa.ts</code> and the Vite plugin, or gate <code>extensions.js</code> and the duplicate head tags behind a preview-only flag, and delete <code>public/_grok</code>. Make per-page OG tags win again (or populate them from <code>pageHead</code>).	M
PERF-4	MEDIUM	Fonts: render-blocking Google Fonts stylesheet with no preconnect or preload, 86 KB of variable fonts, no fallback metrics First paint waits on two third-party origins (extra DNS, TLS and round trips on high-latency mobile links), fonts arrive last, and the headline reflows on swap. Visitor IPs are also sent to Google.	Self-host Figtree (latin, variable) and a Fraunces subset in <code>public/fonts</code>, preload the two woff2 files, declare <code>@font-face</code> with <code>font-display swap</code> and <code>size-adjust/ascend-override</code> fallbacks, and remove the <code>googleapis</code> link. If keeping Google Fonts, add <code>preconnect</code> to both origins.	S
PERF-5	MEDIUM	Entry chunk is 578 kB (177 kB gzip) and carries about 22 kB gzip of zod used only by the Grok preview bridge About 15 percent of the shared JS every visitor downloads and parses is dead weight on the live site.	Load the bridge with a dynamic import only when <code>window.parent !== window</code> (framed preview), or replace the three zod schemas with hand-written checks; this also removes the build warning. Leave the existing route splitting as is.	S
PERF-6	MEDIUM	/images/* has no cache headers configured, so 34 MB of photos revalidate on every visit Repeat visitors and in-site navigation re-issue conditional requests for every image; on a high-latency network each 304 round trip still costs time and keeps images from rendering instantly.	Add Nitro <code>routeRules</code> or <code>vercel.json</code> headers for <code>/images/**</code> and <code>/icons/**</code> with <code>cache-control public, max-age=604800, stale-while-revalidate=86400</code> (or longer if file names become content-hashed in the PERF-2 pipeline), and confirm with <code>curl -I</code> on production.	S
A11Y-4	MEDIUM	Duplicate element ids leave inputs without an accessible name on / and /cruise Screen-reader users hear an unlabelled field in the cruise enquiry form and the footer newsletter; clicking the label focuses the wrong element.	Generate unique ids with <code>useId</code> in <code>NewsletterForm</code> and in the cruise form fields, or rename the section anchors (for example <code>section-excursions</code>). Add a DOM check for duplicate ids to the QA scripts.	S

A11Y-5	MEDIUM	Mobile menu and contact popovers: Escape does not close the menu, focus escapes behind the overlay, popover close drops focus to body Keyboard and screen-reader users lose their place and can interact with controls they cannot see (WCAG 2.1.2/2.4.3/2.4.7).	Close the mobile menu on Escape and return focus to the toggle, set aria-controls and mark the main content inert while open (or use Radix Dialog); remove the onCloseAutoFocus preventDefault so Radix restores focus to the trigger.	S
A11Y-6	MEDIUM	Five independent autoplaying regions on the homepage with no pause on hover or focus Heavy competing motion and screen-reader chatter for cognitive and vestibular users; content changes while being read or targeted with a pointer.	Pause on hover and focus-within in useSlideRotation for all carousels, make the 2 s layered carousel manual or at least 5 s, stop rotation of off-screen carousels with IntersectionObserver, and make counters aria-live off while rotating.	M
A11Y-7	MEDIUM	Required fields are not indicated and no field declares autocomplete WCAG 1.3.5 (identify input purpose) fails for name, email and phone; users do not know which fields are mandatory until a failed submit; mobile users get the wrong keyboard for phone.	Add autoComplete (name, email, tel), inputMode=tel for phone, and a visible '(required)' or asterisk with an explanatory line in Label/Field; keep role=alert for errors.	S
PERF-7	LOW	Carousel autoplay animates the layout property left and produces layout shifts Uses half of the CLS budget with no user input and forces main-thread layout every frame on low-end phones.	Position cards with transform only (translateX from a fixed centre) so no layout is triggered, and reserve the hero text block height so slide changes cannot move the search pill.	M
A11Y-8	LOW	Heading order skips from h1 to h3 on four pages Screen-reader heading navigation shows a broken outline on the main catalogue pages (WCAG 1.3.1).	Add a visually-hidden or visible h2 per section, or let the card components take a heading level prop.	S
A11Y-9	LOW	ARIA tab and radio roles are used without the keyboard pattern or panels Screen readers announce 'tab 1 of 4' and imply arrow-key navigation that does not exist.	Render the dots as plain buttons with aria-current (or aria-pressed), and either implement roving tabindex with arrow keys on the theme radios or use a menu of aria-pressed buttons.	S
A11Y-10	LOW	Very small text, small touch targets and a few weak alt texts Harder reading and tapping on small phones; minor redundancy for screen readers.	Raise kickers to at least 12 px, give footer and breadcrumb links padding to reach 24-44 px, set alt="" on tile images whose text is already in the link, and make generic alts describe the place.	S
RESP-1	LOW	Page overflows horizontally by 10 px at 320 px on /about/sustainability Violates WCAG 1.4.10 reflow at 320 px on one page; small horizontal wobble.	Let the sticky section-nav list scroll inside its own overflow-x container or drop shrink-0 on its items at narrow widths.	S

THEME-1	LOW	Dark first-visit theme does not declare color-scheme, and theme-color and manifest colours ignore it Scrollbars, native select popups, date pickers and autofill render light-scheme chrome on a dark page; installed-app splash and browser UI colour do not match the page.	Set color-scheme: dark on html[data-theme=two] and html[data-theme=three] (light on the others) in styles.css and update the theme-color meta from the theme switcher; align manifest background_color with the first-visit theme.	S
PWA-1	LOW	PWA is manifest-only: no service worker, no offline fallback, no maskable icon Owner No stale-content risk, which is good, but the site is not usable offline and the home-screen icon may be cropped on Android. Whether an offline experience is wanted is a product decision.	Owner to decide if installability matters. If yes: add a maskable 512 icon, and a small, versioned service worker that precaches only the shell and an offline page with network-first for HTML so it can never serve stale pages; otherwise leave as is and remove the duplicate Grok links.	M
DEBT-1	LOW	Nine dependencies are never imported, and tw-animate-css classes are used without the plugin Bigger installs and supply-chain surface (recharts alone is large); the popover open animations the code intends never run.	Remove the unused packages, and either add @import 'tw-animate-css' to styles.css or delete the dead animation classes.	S
PERF-8	LOW	No performance or accessibility regression checks in CI Defects like PERF-1, A11Y-1 and A11Y-4 ship unnoticed and the 6-12 MB homepage can grow further without any signal.	Add a small Playwright smoke in CI against vite preview: assert every stylesheet and script in the HTML returns 200, no duplicate ids, skip link visible on focus, and a transfer-size budget for /, /tours and a tour page.	M

Quality assurance, CI/CD and repository health

19 findings · partial

All four gates pass on the working tree and also on a clean-room copy (tracked plus untracked-unignored files, no .env.local, fresh npm ci). The numbers are tsc 0 errors, eslint 0 errors and 0 warnings, 313 tests (311 pass, 2 skipped for Windows symlink permissions, 0 fail), and build:dev OK. A production-mode vite build without the migrate step also passes, and npm audit reports 0 vulnerabilities. The weaknesses are in process, not code. About two weeks of work is uncommitted or unpushed: the remote main is at 04aef64 from 2026-09-22, there are 4 unpushed commits, and 114 modified or untracked paths including the CI workflow itself. CI has therefore never run, main is unprotected, and Vercel deploys every push to Production. `npm run dev` also loads .env.local, which holds a DATABASE_URL for the Neon production branch, so local development is probably wired to the production database. Few tests cover the live enquiry path, there is no end-to-end or browser testing that works, there is no error tracking, and there is no deployment, backup or restore documentation. The repo also carries many stale status documents and Grok sandbox leftovers. Side effects of the audit: I ran two builds, which overwrote the gitignored .vercel/output; I restored it from a backup (425 files, same content, new mtimes). I also sent one GET to /api/cron/expire-holds on localhost:8080, which executes the hold-expiry transaction; see notVerified.

ID	SEVERITY	FINDING	RECOMMENDATION	EFFORT
----	----------	---------	----------------	--------

REPO-1	HIGH verified	About two weeks of work is uncommitted or unpushed; remote main is stale Owner The only copy of the sustainability page, hospitality preview, legal pages, image-credits page, cron route, test fixes and CI is on one laptop. The only other archive is a 420 MB zip dated 2026-09-09 in the parent folder. A disk failure loses the work. Production cannot receive the legal pages, and anyone cloning the repo gets a different build and test setup from the one that was verified.	With the owner's approval, commit in logical chunks (CI and test tooling, legal pages, sustainability, hospitality, themes) and push them. Do not commit <code>.env.local</code> or the <code>.vercel</code> directory. Push to a branch and open a PR so CI runs once before main is touched. Commit the stable pieces first and keep the hospitality preview behind its existing gate.	S
QA-OPS-1	HIGH verified	Local dev and builds load <code>.env.local</code>, so the dev server is wired to the Neon production database Owner Every local <code>`npm run dev`</code>, including any test or QA enquiry, newsletter signup or registration, probably writes to production Neon. The dev server is also bound to 0.0.0.0, and CLAUDE.md says SUPER_ADMIN is still unclaimed. Anyone on the same network could register and take the single-use SUPER_ADMIN claim on the production database while the dev server is up. The README and <code>.env.example</code> do not warn about this.	Create a Neon dev branch and put only its URL in <code>.env.local</code>. Keep production credentials only in Vercel. Until then, start dev as <code>`DATABASE_URL= npm run dev`</code> so it uses PGLite. Consider binding dev to 127.0.0.1. Document the rule in README and CLAUDE.md. Claiming SUPER_ADMIN on production from the real site, with <code>BOOTSTRAP_ADMIN_EMAIL</code> set, closes the takeover risk.	S
DOC-2	HIGH verified	No deployment, backup/restore, rollback or incident runbook Owner Enquiries and newsletter signups live only in Neon. Nobody has a documented, tested way to restore them, roll back a bad deploy, rotate secrets, or know who deploys and how (push to main is the only visible path).	Write a short RUNBOOK covering: how a deploy happens, how to roll back in Vercel, required Vercel and Neon env vars and scopes, how to restore with Neon point-in-time restore or a snapshot, a periodic <code>pg_dump</code> if the plan's retention is short, a restore drill, and contact and escalation. Confirm the Neon plan retention first.	M
CI-1	MEDIUM verified, adjusted	CI workflow is untracked, has never run, and nothing gates the push-to-production deploy Owner A broken push to main goes straight to production with no automated check. The repo owner and AI agents are told CI exists and may rely on it. There is no pull-request flow, so no preview deployment is reviewed before it ships.	Commit <code>ci.yml</code> and add <code>`permissions: contents: read`</code>. Protect main by requiring the CI check, and work through PRs so Vercel preview deployments get checked before merge. Until then, correct the CLAUDE.md line.	S
TST-1	MEDIUM verified, adjusted	The live enquiry and newsletter path has no tests, and there is no working end-to-end test Enquiries are the site's only conversion path, and it has already broken twice in production. Validation, rate-limiting, the DB insert, the Resend failure-tolerance contract and the form handlers are protected only by manual checks.	Add a PGLite-backed integration test for <code>submitEnquiry</code> (invalid email, rate limit, insert, Resend failure still returns success, with fetch mocked). Add a Playwright smoke that opens each enquiry form on a PGLite dev server (<code>DATABASE_URL</code> blank) and checks the success state. Never point it at production. Run both in CI.	M

TST-2	MEDIUM	DB-backed booking engine, webhook application and rate limiting are untested (only pure helpers are covered) The 'booking engine is tested' premise holds only for the pure logic. Hold concurrency, settlement idempotency and expireHolds SQL are unverified by automation. This is contained for now because online booking is dormant by product rule, but the live webhook routes still exist.	Add PGLite integration tests for concurrent createHoldTx, settleBookingTx idempotency and expireHolds. Delete inventory.ts if it is truly dead. Keep booking dormant and do not expand it.	M
TST-3	MEDIUM	Most of the 313 tests exercise Grok sandbox tooling, and src tests run from a hand-kept file list A green `npm test` says little about the product. A new test file that is not added to the list is never executed and nobody is told.	Replace the explicit list with a glob (<code>node --import ./scripts/register-alias.mjs --experimental-strip-types -test "src/**/*.test.ts"</code>). Prioritise new tests on enquiries, content rules and the DB layer. Retire template tests when the Grok scaffolding is removed.	S
TST-4	MEDIUM	No automated guard for the firm product rules Several people and AI agents edit content. A single regression of a firm rule (wrong contact detail, invented price, a booking verb) would ship straight to production with no automated signal.	Add a small content-lint test that scans <code>src/data</code> , <code>src/routes</code> and <code>src/components</code> for the forbidden phone number, banned phrases, booking verbs, and a <code>priceCents</code> set anywhere in the catalog. Add a check that every image under <code>public/images</code> has a provenance record. Wire it into <code>npm test</code> .	S
TST-5	MEDIUM	Browser smoke and QA scripts are unusable here and nothing browser-based runs in CI The repo has no runnable browser regression check. The Playwright plus Edge QA described in project notes is done by hand each time, so console errors, overflow and broken pages are caught only if someone looks.	Replace these scripts with one Playwright script (channel msedge locally, bundled chromium in CI) that GETs each sitemap route at phone and desktop widths, asserts status 200, no console errors and no horizontal overflow, and writes output to a temp dir. Add <code>screenshots/` to .gitignore</code> .	M
CI-2	MEDIUM	CI scope is narrow: no migration test, no audit, no production-mode build, no least-privilege token A broken migration shows up only when Vercel builds against production. A vulnerable dependency or a production-only build failure is not caught before merge. Linux-specific test failures (not seen on Windows) could surface only on the first CI run.	Add a job that applies <code>migrations/*.sql</code> to a throwaway PGLite or service Postgres. Add <code>npm audit --omit=dev --audit-level=high</code> , <code>permissions: contents: read</code> , and Dependabot for npm and GitHub Actions. Either enforce prettier or drop eslint-plugin-prettier. Run the first CI on a branch and fix anything Linux-specific.	M

QA-OPS-2	MEDIUM	Migrations run inside the Vercel build with unverified environment scoping, no lock, and a history of duplicate projects Owner If Preview deployments have DATABASE_URL, any PR or branch build can alter the production schema. Two parallel builds would run db:migrate concurrently with no lock. Migrations are applied before the new code is live, so a non-additive migration would break the running version. Today's four migrations are additive, so the impact is latent.	Confirm in the Vercel dashboard that DATABASE_URL (and any pooled URL) exists only in the Production scope, and that only one Vercel project is connected to the repo. Add a migration advisory lock. Document an expand/contract rule for schema changes. Put build and install commands in a vercel.json so settings are reviewable.	S
MON-1	MEDIUM verified, adjusted	No error tracking, uptime monitoring or health check; enquiry email failures only reach stdout Owner If Resend, DNS, the database or a deploy fails, nobody is alerted. The enquiry row is stored but cannot be read through the admin screen until SUPER_ADMIN is claimed, so an email failure means a lead is silently missed. Vercel log retention depends on the plan, which I could not confirm.	Enquiry-led and low cost: claim SUPER_ADMIN so /admin can show enquiries; add a free uptime monitor on `'; add a simple Sentry or log-drain integration for server errors; and make failed team notifications visible (an error-level log plus an alert). Do not add online booking or payments.	M
DOC-1	MEDIUM	Stale documents contradict the code New developers and non-Claude agents that follow the root-level files will install the wrong Node, assume Google/X login, trust the wrong audit state or follow Grok sandbox rules.	Move the old status, audit and image reports to a docs/archive folder with a dated note, or delete them. Rewrite README (Node 22.6 or newer, email/password auth only, deployment and env-warning sections). Replace AGENTS.md with a short pointer to CLAUDE.md, and update scripts/brand-check.test.mjs, which reads AGENTS.md and .grok/skills/og/SKILL.md, in the same change.	M
DOC-3	MEDIUM	New-developer onboarding is incomplete Handover or a second contributor depends on reading a very long agent-oriented file. The easiest mistakes (writing to production from dev, forgetting to register a test) are not mentioned where a human would look first.	Add a one-page CONTRIBUTING or expand the README: the four gate commands, the product rules, the env and branch policy, and a link to the runbook. Keep CLAUDE.md for agents.	S
REPO-2	MEDIUM	Grok sandbox scaffolding and dead code remain in the production repo Owner More surface to maintain, patch and audit, and confusing signals for new developers and AI agents. Removing it carelessly breaks `npm test`.	Remove it in stages after approval: dead files first (p2p.ts, inventory.ts, startup.sh, duplicate .agents skills), then the Grok preview tooling together with its tests. Keep the Vercel-relevant pieces (the PWA manifest plugin) until reviewed.	L
DEP-1	MEDIUM	Dependency drift: 55 outdated packages, 11 a major version behind, and a pinned beta server runtime The production server runtime is a beta and the auth library is a minor version behind, with no automated update flow. Drift makes later upgrades larger and riskier.	Add Dependabot with a monthly schedule and grouped minor/patch updates. Plan a small upgrade pass for react, vite, tanstack, better-auth and nitro with the full gate set. Leave typescript 7, eslint 10 and other majors for a dedicated change.	M

OWN-1	MEDIUM	Dashboard facts the owner must confirm (Vercel and Neon settings not visible from the repo) Owner Several findings above (OPS-1, OPS-2, MON-1, DOC-2) cannot be closed without these answers.	Ask the owner to confirm those settings (screenshot or text, never secret values) and the decision to protect main and require CI.	S
DEP-2	LOW	About 25 direct dependencies are not referenced by any source file Longer installs and a larger audit and update surface (some are among the major-version-behind packages above), with no benefit to users since unreferenced code is not bundled.	Remove the unused packages after a build, then re-run the gates. Keep react-dom and @tanstack/router-plugin.	S
REPO-3	LOW	Repo hygiene nits: .gitignore defects, line endings, history size, large client chunk Small. Someone adding a new env sample file will find it ignored. Line-ending noise appears in diffs. Fresh clones download 200 MB.	Clean the .gitignore (remove `{}` and the duplicate, add `!.env.example` after `.env*`). Add .gitattributes with `* text=auto eol=lf`. Delete the scratch directories once the owner has confirmed. Do not rewrite history. Consider code-splitting the large entry chunk later.	S

Legal, compliance, brand and image rights

20 findings ·  partial

The legal layer has moved from nothing to a credible first draft. Privacy, Terms and Cookies pages exist, are footer-linked, read honestly, and match the site's own code on analytics and first-party cookies. A footer-linked image credits page lists all 35 CC BY and BY-SA works. The biggest gaps are things the pages do not say or the code does not do. A grok.com script and Grok-branded middleware are injected into every page and are undisclosed. 24 live images have no recorded licence, including the homepage island hero and the 21 vehicle photos. The newsletter and enquiry forms have no consent or notice and no unsubscribe. A third party outside the company silently receives every enquiry. The Terms say the site publishes no prices while vehicle pages show 'From \$35/day' and other rates. The 1 DCM World, AFAR, 'licensed guides', testimonial and review-count claims have no source in the repo. All legal text still needs a lawyer. I did not fetch the live production host, Pexels, Wikimedia Commons, or the grok.com script.

ID	SEVERITY	FINDING	RECOMMENDATION	EFFORT
LEG-6	HIGH verified	Terms say the site publishes no prices, but vehicle pages show daily rates and 'AVAILABLE' status Owner The site's own legal text and homepage promise contradict the page content. Published rates and live-looking availability for a fleet nobody has confirmed are unsupported commercial claims.	Owner to confirm the real fleet and rates. If not confirmed, replace rates and availability with 'Price on request' and 'Request a quote', as the hospitality preview does. If confirmed, change the Terms and homepage wording to match and add currency and conditions.	S

LEG-1	MEDIUM verified, adjusted	Grok platform script and Grok-branded middleware are injected into every production page, undisclosed Owner A remote third-party script runs on every page, including the enquiry, newsletter and register forms, which is a supply-chain and privacy exposure. It contradicts the privacy and cookies pages, which name only Google Fonts and OpenStreetMap, and it sets a cookie the cookies page does not mention. It overwrites page-specific share metadata with a generic card. It also leaks Grok branding (install tutorial, manifest, icons) on a real business site.	Decide with the owner whether the Grok platform features are wanted. If not, remove grokPwaPlugin() and the nitro serverDir/server/middleware/grok-pwa.ts wiring, delete public/__grok/ and scripts/install-page.html, rebuild, and re-test with Playwright that no grok.com request or cookie remains and that per-page og tags survive. If the script must stay, disclose it in both policies and have a lawyer review it. Then confirm on the live host with a browser or curl.	S
LEG-2	MEDIUM verified, adjusted	24 live images and 12 served-but-unused files have no recorded licence; 2 live files and 1 manifest entry are out of sync Owner There is no evidence of the right to use these images, so any takedown or claim is undefendable. Unreferenced files are still downloadable from the public CDN. The manifest, which the credits page and the audit trail depend on, is incomplete.	For each of the 36, record source, author and licence, or replace the file. The vehicle files can probably be traced from scripts/download-vehicle-images.mjs (see LEG-10). Add entries for bunce-tasso-national-parks.jpg, og-image.jpg and og.jpg. Remove the orphaned bunce-island-cannon entry or restore the file. Delete unreferenced unverified files from public/, or move them out of the deployed tree. Stop publishing internal notes in the public JSON, or move the manifest out of public/.	M
LEG-3	MEDIUM verified, adjusted	Homepage hero slide 4 uses an owner-supplied aerial of unconfirmed place and unknown rights Owner The most-viewed section of the site shows an image whose copyright holder and location nobody has confirmed, next to copy that implies it is a Sierra Leone island. That risks a copyright claim and a misleading-place claim.	Owner to supply the photographer's name and written permission, and the real location, or replace the slide with a documented Sierra Leone image (for example a CC-licensed Banana Islands photo already in the manifest). Until then, drop the slide.	S
LEG-4	MEDIUM verified, adjusted	Every enquiry is silently copied to an external UK address; forms carry no privacy notice Owner Visitors, including EU/UK cruise passengers and diaspora, send personal data without being told it goes to a separate business outside Sierra Leone. Under most privacy laws that recipient is a separate controller or a processor and needs naming, a lawful basis and an agreement. A private individual's email address is also published in the policy.	Owner to confirm who the recipient is, why they receive every enquiry, and whether to keep it, narrow it (for example partner enquiries only) or add a written data-sharing agreement. Add a short notice and privacy link above each submit button naming the recipients. Have a lawyer confirm the wording.	S

LEG-5	MEDIUM verified, adjusted	Newsletter: no consent wording, no confirmation, no unsubscribe, no consent record; policy mis-describes what is stored A marketing list with no provable consent and no self-service opt-out is a compliance risk for EU/UK/US recipients the moment anyone is emailed. The privacy statement about stored data is inaccurate. There is also no tooling to send or manage the list.	Add one line under the field ('We will email you occasional itinerary notes. Unsubscribe any time. See Privacy') with a link. Use a confirmation (double opt-in) email via the existing Resend wrapper, store consent time and wording version, and add an unsubscribe link and endpoint. Fix the privacy sentence or record the real source page. Do not mail the list until this is done.	M
LEG-7	MEDIUM	Privacy policy lacks required elements and has points that do not match the code Owner The policy is a good plain-language draft but would not satisfy a regulator or an EU/UK visitor's rights request. Several statements are not verifiably true.	Lawyer to rewrite with: legal entity and registration, contact, lawful bases, retention schedule (for example enquiries 24 months), rights and complaint route, transfers, and the processor list matching production env (Vercel, Neon, Resend, Upstash, Twilio if used). Define a manual or admin process for deletion requests and document it.	M
LEG-8	MEDIUM	Third parties receive visitors' IP addresses on page load with no choice (Google Fonts, OpenStreetMap, grok.com) Remote font loading before consent has led to GDPR damages claims in Germany (a Munich court ruling, 2022; a lawyer should confirm). The visible map is always Freetown even for Guinea or Liberia tours.	Self-host the two fonts (for example via fontsource), replace the iframe with a click-to-load map or a plain link, remove grok.com (LEG-1). With those gone no consent banner is needed and the policy can simply say no third parties load on page view.	M
LEG-9	MEDIUM	Image credits page has gaps against CC attribution terms CC licences require crediting the creator and, under 4.0, indicating changes. Missing authors, a missing version and an inaccurate 'as published' note put the licences at risk of being treated as breached.	Re-read each of the 16 Commons pages and record the author or uploader, or replace those images. Pin the version for the 'CC BY' entry. Change the note to say images were resized and compressed, and that the resized copies are available under the same licence. NOT VERIFIED whether the Commons pages do name authors.	M
LEG-10	MEDIUM	Vehicle photos are stock from other countries, recorded as 'Sierra Leone' with no source; one contradicts the copy beside it Owner A false location record, copy that implies Sierra Leone terrain from a desert photo, and stock photos presented as a named fleet are misleading. Pexels and Pixabay licences are permissive, but their terms bar implying endorsement by pictured people or brands, and the licence is unrecorded.	Record the Pexels or Pixabay IDs and photographers in image-sources.json and set the correct location. Label vehicle images as stock where they are not the company's own fleet, change the dunes image to something that fits the copy, and ideally replace the set with photos of real vehicles. Owner to confirm the fleet.	M

LEG-11	MEDIUM	Third-party and credential claims with no source: 1 DCM World, AFAR Magazine, 'licensed guides' Owner Membership and press claims on every page, and licence claims, are unverifiable. If wrong or lapsed, they are misleading and risk a complaint from 1 DCM World or the publications.	Owner to provide a link to the Travel And Tour World and AFAR pieces and proof or written permission from 1 DCM World, then link the citations. Confirm what guide and operator licences exist and show registration numbers. Remove or soften any claim that cannot be evidenced.	S
LEG-12	MEDIUM	Homepage testimonial names a private individual and his social handle, with no source, date or evidence of consent Owner Publishing a named person and handle as an endorsement without consent is a personal-data issue, and an unverifiable testimonial is a consumer-protection risk. The quote itself does not say he used the company's services.	Owner to confirm where the quote came from and get written permission, or remove it, or use first name and country only. Add the platform and date, and only describe it as a review if the person actually travelled with the company.	S
LEG-13	MEDIUM	Tour pages show star ratings and review counts attributed only to 'the public catalogue' Owner Aggregate ratings with no named platform or date are an unverifiable consumer claim and contradict the site's own 'no invented ratings' rule.	Owner to name the source (platform, date) or remove the numbers until real, moderated reviews exist.	S
LEG-14	MEDIUM	Logo and social-share image have no provenance or trademark evidence; share image appears to be a generated render Owner If the logo or share image was generated or bought from a designer, the owner may not hold clear copyright, and an unregistered mark gives weak protection. A rendered 'West Africa' share image conflicts with the real-photography rule.	Owner to confirm who made the logo and share image and under what terms, get the source files and a written assignment, and decide whether to register the mark. Replace og.jpg with a real, credited Sierra Leone photograph, and make the share image setting consistent.	S
LEG-15	MEDIUM	Terms are thin and need lawyer review; they omit entity, governing law and stock-image disclosure Owner Terms that do not name the contracting entity or applicable law are hard to enforce and may be unfair to consumers. Limitation wording (:82-87) is generic and untested.	Lawyer to confirm the contracting entity and registration, governing law and courts, how cancellations and written quotes work, the supplier-liability position, and package-travel rules for the main source markets. Keep the 'no online booking' stance.	M
LEG-16	LOW	Cookies page omits some browser storage; it describes the map loosely The page is not a complete list, which matters because 'Stay & Dine' is in the main nav and saving a place writes storage.	Add 'til-saved-places' (saved places on this device), correct the map sentence, and add any cookie from remaining third parties. Re-run the Playwright storage check after LEG-1 and LEG-8.	S
LEG-17	LOW	Account sign-up has no terms or privacy notice and implies booking features that are switched off Anyone can create an account that stores a password hash and name with no notice, and the copy implies vouchers and checkout that the product rules say are dormant.	Add privacy and terms links to /register, change the copy to enquiry-led wording, and set noindex until accounts are a real offering.	S

LEG-18	LOW	Social profile links are unverified and one carries a tracking parameter Owner Wrong or hijacked profile links send visitors to someone else's page. The share link may break.	Owner to confirm each profile belongs to the company and give canonical URLs (strip '?si='); then re-check the links.	S
LEG-19	LOW	Staff photos and names published with no recorded consent Owner Publishing an employee's photo and role without recorded permission is a personal-data and privacy-of-staff risk, and removal requests need a process.	Get short written consent from each person, store it, and note it in the manifest.	S
LEG-20	LOW	Stale project docs and leftover research files around legal and image status Future work can rely on stale claims, and the useful provenance evidence is in untidy scratch folders that the owner has been asked to delete.	Update CLAUDE.md's open-items list. Before deleting scratch folders, move any author and source data into image-sources.json.	S

Method, limits and what was not verified

Eight auditors each examined one area of the project from the current code, the local development server and the public site. They were restricted to read-only actions: no files changed, no production data read or written, no forms or enquiries submitted, and environment files inspected by key name only. Each finding had to carry concrete evidence such as a file and line reference, a command result or an HTTP response.

Every critical and high finding was then given to a separate reviewer instructed to refute it by re-checking the evidence independently. Findings were kept, adjusted or removed according to that review; the severity in the register is the verified one. A final completeness review looked for areas the main audit did not cover.

Limits: production data was not read, so the state of the admin account and live records is inferred from code and documentation. DNS, hosting dashboards and third-party accounts were not changed. Legal observations are not legal advice and should be confirmed by a qualified lawyer.

Disclosure of audit side effects: one auditor sent a single GET request to the local hold-expiry route, which runs a transaction that only marks already-lapsed seat holds as expired. Because local development currently loads the production database address (finding QA-OPS-1), that transaction may have run against production. It changes nothing a normal booking request would not also change, and no rows are expected to have been affected. Builds run during the audit overwrote the ignored local build output, which was restored afterwards. No source file was changed.

Completeness review: areas the main audit did not cover

AREA	SEVERITY	WHAT WAS FOUND
Production serves none of the legal or policy pages (deploy gap, not content gap)	HIGH	Checked with HTTP GET on 2026-10-07. Live (www.tourismislife.com) returns 404 for /privacy, /terms, /cookies, /about/image-credits and /hospitality. The dev server returns 200 for all of them. The live homepage HTML contains no link to any of them (grep for href=/privacy/terms/cookies/about/image-credits returned nothing). The live footer has only 'Coming Soon', and live pages still have enquiry, newsletter and sign-up forms. So production currently collects names, emails, phone numbers and trip details with no privacy notice, no terms and no CC BY-SA attribution page. The live enquiry-form chunk (/assets/enquiry-form-BceJNbMq.js) is the pre-legal version. CLAUDE.md still says 'No legal pages', which is true for production and false for the repo. LEG-4 ('silently copied to an external UK address') is literally true on production, because the disclosure sentence exists only in the unpublished privacy page (src/routes/privacy.tsx).
Legacy URL continuity: no redirects from the previous WordPress site	MEDIUM	The Wayback CDX index shows about 133 distinct HTML paths on tourismislife.com from 2022 onward, for example /about-us/, /bintumani/, /banana-island/, /gola-forest/, /bunce/, /airport-transfers/, /air-ticketing/, /hotel-reservation/, /landing-visa/, /medical-evacuation/, /travel-advice/, /travellers-information/, /terms-and-conditions/, /blog/, /book/ and /cruise-ship-handling/. I tested 39 of them against live www with redirects followed. 34 end in HTTP 404 and 5 resolve (/contact, /services, /services/vehicle-rental and two others). Example: /bintumani/ ends at 404 and /mice/ ends at 404. The repo has no redirect mechanism: no redirects or routeRules in vite.config.ts, no vercel.json, and ROUTE_MIGRATION.md maps only blueprint routes, not old URLs. Any backlinks from partners such as 1 DCM World, the tourist board or tour-operator pages that pointed at deep URLs now land on a 404. The old site also had dedicated Landing Visa, Medical Evacuation, Travel Advice, Travellers Information and Hotels pages (archived titles confirmed, 3-4k characters each). Most of those topics are absent now, which overlaps PC-5, and the retired Landing Visa and Medical Evacuation services need an owner decision.

**Handover, ownership
and continuity of
accounts**

HIGH

Evidence of single-person, personal-account ownership. All 22 commits are by one author. The git remote is a personal GitHub account (EngineerMAJalloh114). `vercel env ls` shows the Vercel project under scope 'softcodes1', not a business-named team (plan tier NOT VERIFIED; Vercel's Hobby tier is limited to non-commercial use, so confirm the plan). Neon is a personal free-tier account (OPS-3). DNS is hosted at SiteGround (NS ns1/ns2.siteground.net, SOA admins.siteground.com) and the registrar is Network Solutions (RDAP: registered 2016-09-10, expires 2029-09-10, which is a strength). Mail is Microsoft 365 (MX tourismislife-com.mail.protection.outlook.com). Resend holds the sending domain. Because DNS sits in the SiteGround account, lapsing or cancelling that hosting plan could take down both the website and the info@ mailbox. The old WordPress site, its media library and its form data very likely still live there. RDAP lists only status 'active' with no transfer-lock status and no DNSSEC, so the registrar lock is NOT VERIFIED. No document in the repo records who holds each login, the recovery emails, or the renewal dates. DOC-2 covers the missing runbook but not ownership. Business-side owner of each account: NOT VERIFIED.

**Irreplaceable image
assets exist only on one
laptop**

MEDIUM

`git ls-files --others --exclude-standard public/images` lists 13 untracked files. They are the 3 staff portraits (team/alieya-alie-kargbo.jpg, isha-bangura.jpg, peter-momoh-bassie.jpg), 7 service photos (services/*.jpg) and 3 owner-supplied aerials (beaches/peninsula-beach-palms.jpg, beaches/sandbank-aerial.jpg, islands/island-aerial-settlement.jpg). The staff portraits and service photos are referenced from uncommitted src changes (the team array in src/data/catalog.ts and the service data). Live returns 404 for /images/team/alieya-alie-kargbo.jpg, /images/team/isha-bangura.jpg, /images/services/ticketing.jpg and /images/islands/island-aerial-settlement.jpg. So these files are in neither git nor production. The only archive is a 420 MB zip dated 9 Sep that predates them. Delivery is also repo-only: public/images is 34 MB across 87 files, there is no object store (src/services/storage.ts is a URL helper only), and full-resolution originals are not kept anywhere. The ignored dirs .image-research-tmp, .vehicle-img-tmp and attachments (about 29 MB) hold the only copies of research candidates. Whether the owner holds originals elsewhere: NOT VERIFIED.

**Enquiry response
workflow: promises
with no mechanism
behind them**

HIGH

Promises: 'replies within 24 hours' appears in src/routes/contact/index.tsx:12,24 and src/routes/services/tours-excursions.tsx:229 ('a person reads every message'). '24/7 emergency' is in src/lib/site.ts:23 and the footer. A '24-hour support desk' is on the cruise pages. No rota, owner, out-of-hours rule or time zone is recorded anywhere. Visitor confirmation (live bundle confirms this string): enquiry-form.tsx:99 says 'Received. The public site describes replies within 24 hours.' This is internal wording, and the reference number (ENQ-xxxxxx) returned by submitEnquiry is never shown. The auto-reply (notify.ts notifyEnquiryReceived) is one sentence, is not branded, and puts the raw enum in the subject and body ('We received your B2C enquiry ENQ-...'). It has no phone, WhatsApp or expected-reply information. Staff side: the notification goes to a shared info@ inbox in Microsoft 365 plus a third-party address. There is no assignment, no SLA clock, and no way to reply from /admin (status is only open/closed and /admin is unclaimed). Sample-listing enquiries from Stay & Dine (stay-detail.tsx tags them SAMPLE) would reach the real desk, and the dialog tells the visitor 'Our team checks availability with the property'. No such property exists. The pending deploy swaps the primary number: live shows +232 79 616 668 as Phone and as the 24/7 line, while src/lib/site.ts (uncommitted) makes +232 76 568 335 primary and 24/7. Which number is actually staffed 24/7: NOT VERIFIED, owner-input. I did not POST to any enquiry endpoint, so end-to-end delivery from production is NOT VERIFIED.

Email deliverability and domain mail setup (documented, not editable from the repo)

MEDIUM

Read-only DNS lookups on 2026-10-07. MX points to Microsoft 365. Apex SPF is 'v=spf1 include:spf.protection.outlook.com include:tourismislife.com.spf.auto.dnssmarthost.net -all', which does not include Resend. Resend is set up correctly on its own subdomain: send.tourismislife.com has an SPF TXT and a CNAME to send.forge.rmta.net, resend._domainkey exists (a 1024-bit key) and a resend-domain-verification TXT exists. DMARC is p=none with relaxed alignment (SEC-11). New finding: selector1._domainkey and selector2._domainkey do not exist (NXDOMAIN at both the resolver and ns1.siteground.net), so Microsoft 365 DKIM signing is not enabled. Staff replies from info@ therefore pass DMARC on SPF only. That is fine at p=none, but DMARC cannot be tightened until M365 DKIM is enabled. RESEND_API_KEY and RESEND_FROM exist in Production (names only, via `vercel env ls`), so sending is configured. Mail is sent from and to the same address (info@), and no seed test was possible, so inbox placement versus spam in M365 is NOT VERIFIED.

Content operations: who can change the site, and how

MEDIUM

All catalogue, journal, team and testimonial content is TypeScript source: src/data/catalog.ts (1,221 lines), cruise.ts (543), vehicle-rental.ts (496), hospitality.ts (413) and sustainability.ts (348). Journal posts are strings inside the `articles` array, with `\\n\\n` used as paragraph breaks. /admin/tours (src/routes/admin/tours.tsx) is a read-only list with a 'View' link. There is no content editor, no image upload (storage.ts has no client), and no newsletter composer (OPS-11). Every phone number, tour, photo or article change therefore needs a developer, a git commit and a production deploy, and the deploy is a direct push to main (CI-1). There is no staging, and the Preview environment has no variables (OPS-18). No editorial or change procedure is documented, and README and CLAUDE.md describe developer conventions only. Result: the owner cannot publish a new tour, correct a fact or add a journal article without the one developer. Options for the owner to choose between: a documented developer-only process with a turnaround time, or a Git-backed editor on top of the existing data files (not a rewrite).

Analytics and conversion measurement beyond 'no analytics'

MEDIUM

Live homepage scripts are only grok.com extensions.js and the app bundle; no GA, GTM, Plausible, Vercel insights, Clarity, Sentry or similar (grep of fetched HTML). Beyond that: (1) enquiries are written with columns id, user_id, type, payload, status, guest_email, guest_name, created_at (migrations/0002 and 0003), so there is no source page, referrer or campaign column. Only some forms add a free-text `context`, and the general contact and travel forms add none. (2) The B2C form has no country, preferred contact channel, budget band or 'how did you hear about us'; the cruise form does ask country. (3) A successful submit only toggles inline text with no URL change, whereas the archived old site had a dedicated /enquiry-thank-you-page/, so goals cannot be defined by URL. (4) Clicks on tel:, wa.me and mailto: links (the main contact route for this market) are not observable. (5) The privacy page (src/routes/privacy.tsx) and cookies page (src/routes/cookies.tsx) state 'we do not run analytics', so adding any tool also requires changing both policies. A cookieless tool would avoid needing a consent banner. No target, KPI or baseline is written down in the repo.

Tour-page enquiry path loses context (conversion leak)

MEDIUM

src/routes/tours/\$slug.tsx: the on-page EnquiryForm with contextLabel={tour.title} renders only when !tour.bookable (lines 182-185, 6 of 22 tours) and sits below Reviews and FAQs. The sidebar 'Request a quote' for those tours links to plain /contact (line 210) with no tour parameter, so the context is lost. On the 16 bookable tours the only CTAs are 'Select dates' (lines 204 and 235, including a sticky mobile bar) and 'Save tour', which redirects visitors to /login (line 224). Those 16 tours have no tour-aware enquiry at all. Cards on the homepage and in listings say 'Check availability' (tour-card.tsx:68, editorial-feature-card.tsx:46, index.tsx:60,80). Removing the hold flow (PC-1 and BK-1) without first adding a contextual enquiry CTA would leave the core tours with no conversion path.

Cruise B2B funnel completeness	MEDIUM	Live and local /cruise name an operations officer (Sonia Koroma) and a travel director with no phone, email or WhatsApp next to them (live /cruise text lines 39 and 334 show only the global header and footer numbers). The officer is not on the Team page. Two different cruise request forms exist: EnquiryForm CRUISE at /cruise/quote (free-text 'Arrival date & time', no company, no country) and CruiseInquiryForm on /cruise#inquiry (date inputs, excursion select, company, country, departure date). The desk receives two payload shapes. The 48-hour vessel information and documentation checklists ask for crew, passenger and cargo lists, but the only channel is email, with no secure upload. /cruise/case-studies says 'Detailed cruise case studies are not published' and lists journal titles. Trust documents are absent: no company registration, tourist-board licence, insurance certificate, safety or incident procedure, sample programme or downloadable brochure or rate sheet (no PDFs in public/). The only trade-credential strings in src are 'Comprehensive bus insurance' and 'Licensed guides'. Port facts, 50% deposit and 3-week balance terms come from a 2024 proposal (cruise.ts:2,335). Also, 'Fresh water, bunkering, ship chandler' are shown as services 'listed in the proposal'. Owner must supply the credentials, a named contact route and an agreed rate-card policy.
Social proof and trust signals: credentials, partner logos and a way to collect real reviews	MEDIUM	(1) Review collection is structurally closed. submitReview (src/lib/server/ops.ts:329) accepts reviews only for a CONFIRMED booking owned by the signed-in user, which requires the dormant hold, checkout and payment flow. Live tour pages show '4.1 / 5 (25 reviews on the public catalogue)' directly above 'No moderated reviews yet.' (confirmed in live HTML for /tours/freetown-city-tour). There is no Google, TripAdvisor or post-trip email route. Presence of the company on third-party review sites: NOT VERIFIED (one web search found nothing by brand name, which is inconclusive). (2) The archived old site displayed partner logo sliders (slugs 1dmc, air-promotion-group, national-tourist-board, tour-operator); the new site shows none, only text claims about 1 DCM World, AFAR and Travel And Tour World (LEG-11). Whether the owner may use those logos: owner-input. (3) The only named testimonial is four words (catalog.ts:1180-1184). (4) No trade registration, tourist-board licence or insurance statement appears on any page.
Definition of success and the offline purchase journey are unwritten	MEDIUM	No document in the repo states goals or targets (README, CLAUDE.md, BUILD_STATUS, MIGRATION_* describe code, and several are stale). The site says 'Quotes are confirmed in writing' (homepage) and 'Confirm in writing before payment' (tour sidebar), and cruise says 'Payment details are provided during confirmed booking and invoicing'. Nothing explains the steps after a quote: deposit size, accepted payment methods (bank transfer, mobile money, card link sent by staff), currency, cancellation and refund terms, or what the traveller receives (itinerary, voucher, contract). PC-27 notes Terms omit cancellation, and PC-6 notes the FAQ describes a booking flow. The new fact here is that the operating procedure behind those pages (quote template, price source, who approves) is not recorded anywhere, so the 'never invent prices' rule cannot be satisfied for the vehicle and cruise figures until the owner supplies a rate source.
Internationalisation	LOW	Everything is English only (html lang="en"; no i18n code; SEO-13 notes no hreflang). New fact: the public page /coming-soon (src/routes/coming-soon.tsx) tells visitors a 'French-language site' and deeper Guinea and Senegal product are planned, which puts the gap on the record without a date or owner. The language, currency and account controls were removed from the header (git log b7ab181). Spelling mixes US and UK ('traveler' 25 hits versus 'traveller' 16, 'organization' 16, and 'Inquiry' 11 versus 'enquiry' 119 in src), while the product rule calls for enquiry language. No prices, so currency is not yet an issue. A decision is needed: ship French pages for the Guinea tours, or remove the promise. Krio and other languages: not examined.

Third-party embeds: the only embed is a generic map on every tour page	LOW	The only iframe in src is the OpenStreetMap embed in <code>src/routes/tours/\$slug.tsx:146-150</code> . It appears on all 22 tour pages, has no <code>loading="lazy"</code> , and uses one fixed Freetown bounding box (<code>bbox=-13.35,8.35,-13.1,8.55</code>) with title 'Freetown, Sierra Leone'. Live <code>/tours/mano-river-triangle</code> (Guinea, Sierra Leone and Liberia) renders the same Freetown map, and so would Gola, Bintumani and the Guinea and Liberia tours. The caption says 'Exact pickup is on the voucher', which refers to the dormant voucher flow. There are no YouTube or Vimeo embeds and no map on the contact page (the YouTube channel is link-only). Google Fonts and OSM IP disclosure is already covered (LEG-8).
Downloadable and printable collateral for B2B readers	LOW	'DMC Brochure' (<code>/brochure</code> , in the About nav) is an HTML page. There are no PDF files in public/ (find over public returned none), no 'download' or 'print' controls anywhere in <code>src/routes</code> or <code>src/components</code> , and <code>styles.css</code> has 0 @media print rules, so printed tour pages and the brochure carry the full site chrome. Owner decision: supply a real brochure and fact sheet PDF; a print stylesheet is a cheap code fix.
Policy and utility pages absent: accessibility statement, FAQ, press, thank-you	LOW	On the dev server (current code) <code>/accessibility</code> , <code>/faq</code> and <code>/thank-you</code> return 404; on live <code>/faq</code> , <code>/faqs</code> , <code>/press</code> , <code>/gallery</code> , <code>/video</code> , <code>/humans.txt</code> and <code>/.well-known/security.txt</code> also return 404. No route or link contains an accessibility statement (grep of <code>src/routes</code> , <code>components/layout</code> and <code>data</code>). <code>robots.txt</code> is minimal. These are not legal requirements for a Freetown DMC, but cruise lines and EU or UK partners often ask for them, and the A11Y findings give the statement real content to publish.

Findings refuted during verification

None. Every critical or high finding survived verification, though several were downgraded.

Not verified

- **Product and content completeness:** Production behaviour: everything was checked against the dev server on localhost:8080. Production headers, redirects (www vs non-www), the sitemap host, the error-screen versus 404 behaviour and real deployed data were not checked.
- **Product and content completeness:** Whether an online payment can actually complete: only env key names in `.env.local` were inspected (no Stripe or Monero keys locally). Production environment variables, the Vercel configuration and the checkout, payment, voucher and webhook steps were not exercised. The booking hold was not submitted, because that would POST.
- **Product and content completeness:** Real sources for the tour ratings and review counts, the vehicle rates and fleet, the cruise prices, the circuit best-time ranges, the Bunce Island founding date (the brochure says 1668, the tour data says around 1670), and the claims about 1 DCM World membership, AFAR coverage, Travel And Tour World and the Oasis Overland partnership. The owner's original documents were not available.
- **Product and content completeness:** Enquiry delivery: the enquiry form, the hospitality InquiryDialog, the newsletter and the cruise form were not submitted, so email delivery, the partner CC and the 24-hour reply claim are untested.
- **Product and content completeness:** Image rotation and quality were checked only on the files viewed, `outamba-mountain.jpg`, `karangia-trail.jpg` and `cotton-tree-freetown.jpg`. The other roughly 70 images and their licences were not reviewed one by one.
- **Product and content completeness:** Mobile and desktop visual layout, accessibility and contrast were out of scope for this dimension and were not assessed.
- **Product and content completeness:** Hospitality: only the page copy was reviewed. The detail dialog, favourites and filters were not exercised.
- **Product and content completeness:** The audit's final output is requested 'in a pdf'. Assembling that PDF is left to the orchestrating step, because this task allowed no files in the project and I only returned structured findings.
- **Data, backend and operations:** Production database contents. Per the read-only rule no production rows were read. Whether `staff_profiles` or `bootstrap_lock` are still empty is taken from CLAUDE.md (25 Sep), not re-checked, and how many enquiries exist is unknown.
- **Data, backend and operations:** That a live enquiry actually reaches `info@tourismislife.com`. Public DNS shows Resend verification, DKIM and SPF records, but the verified status in the Resend dashboard, Resend quota, and inbox delivery were not checked. No form was submitted.

- **Data, backend and operations:** The value of `BOOTSTRAP_ADMIN_EMAIL`, which was never read. Only that the variable exists in Production is known.
- **Data, backend and operations:** Vercel plan, log retention, and whether pushes to GitHub auto-deploy. The `git-main` alias exists, but the deployment owner is a user account and last deploy time precedes the last push.
- **Data, backend and operations:** Runtime behaviour of password reset, sign-in and sign-up error handling, and raw error display. These were derived from library source and app code, not POSTed.
- **Data, backend and operations:** pg pool behaviour on Neon suspend or idle connection loss, and the effect of the 8 s Resend timeout under load. These come from code reading only.
- **Data, backend and operations:** Whether the next ``npm run build`` migration is a no-op on production. Project notes say 0001-0004 were applied on 10 Sep, but the production `_migrations` table was not read.
- **Data, backend and operations:** Backups beyond Neon's 6-hour history. Whether any external backup exists outside this repo was not found.
- **Data, backend and operations:** Resend sending limits and plan.
- **Data, backend and operations:** The Preview-deployment behaviour (PGLite fallback, open bootstrap) is inferred from `env.server.ts` and the empty Preview env. No preview deployment was opened.
- **Data, backend and operations:** One unauthenticated GET to `/api/cron/expire-holds` on the local dev server returned 200 (allowed in preview mode). The dev server runs on in-memory PGLite because the vite process is started without any `DATABASE_URL`.
- **Security, authentication and admin access:** Whether `SUPER_ADMIN` has already been claimed, and the actual `BOOTSTRAP_ADMIN_EMAIL` value. Both are hidden, and checking would need a login or production database access, which I did not touch.
- **Security, authentication and admin access:** Runtime behaviour of sign-up, sign-in, password reset, failed-login handling, rate-limit responses and the exact Set-Cookie attributes. All need POST requests or form submission, which were off limits. These are verified from code and library source only.
- **Security, authentication and admin access:** What `https://grok.com/grok-app-builder/extensions.js` does. I confirmed it is loaded live but did not fetch it.
- **Security, authentication and admin access:** Whether `VERCEL_ENV` is exposed to the production function (inferred from the code comment at `env.server.ts:21-37`), and the strength or length of `BETTER_AUTH_SECRET` (value hidden).
- **Security, authentication and admin access:** Vercel Deployment Protection settings for preview URLs, and Neon-side controls (role privileges, IP allow-list, backups). The Neon database was not queried.
- **Security, authentication and admin access:** Whether the live bundle contains the dormant booking and payment server functions, since the live deploy is older than the working tree. Live `/checkout` and `/booking` are 404, and the cron route is 404 live.
- **Security, authentication and admin access:** Authenticated-role behaviour (a real `STAFF`, `ADMIN` or `SUPER_ADMIN` session) was not exercised; role checks are verified by code reading and by the anonymous `Unauthorized` responses.
- **Security, authentication and admin access:** Side effect to disclose: I made one GET to `http://localhost:8080/api/cron/expire-holds` (HTTP 200), which runs the idempotent `expireHolds` update on whichever database the dev server uses (PGLite per `vite.config.ts` reasoning). I also made GET-only requests to the public live site (headers, a few public paths, the home HTML and one JS bundle, `OPTIONS` preflight, DNS TXT lookups) and one read-only `'vercel env ls'` (names only). Nothing was written, no forms were submitted, and scratch output went only to the scratchpad.
- **Dormant commerce, accounts and vouchers:** Production configuration and the deployed commit. I did not fetch `www.tourismislife.com` (only the dev server was in scope) and could not read Vercel env: `VERCEL_ENV`, `BETTER_AUTH_URL`, `BOOTSTRAP_ADMIN_EMAIL`, `CRON_SECRET`, `STRIPE_*`, `MONEROO_*`, `RESEND_API_KEY`, Upstash and `DATABASE_URL` scoping per Production/Preview. The `.vercel/output` build is dated Sep 25. So whether production is classed 'deployed' (demo off) is proven for the code only, not for the live host.
- **Dormant commerce, accounts and vouchers:** Whether `SUPER_ADMIN` has been claimed and what `BOOTSTRAP_ADMIN_EMAIL` is set to: production DB and env were not read (CLAUDE.md from Sep 2026 says unclaimed).
- **Dormant commerce, accounts and vouchers:** The end-to-end hold -> guest details -> payment screen -> failure path was traced in code, not executed in a browser: POSTs, form submits and booking server functions (including GET `getAvailability` and `getCheckoutBooking`, which run an `expireHolds UPDATE`) were off limits, and I do not know whether the dev server uses PGLite or Neon. The Edge crawl and screenshots were GET navigations only; no writes occurred.
- **Dormant commerce, accounts and vouchers:** Auth form behaviour (silent failed sign-in, non-functional password reset) is established from `better-auth 1.6.30` and `better-fetch` source plus the app code, not by submitting the forms.
- **Dormant commerce, accounts and vouchers:** The 31 hashed server-function ids come from the local Sep 25 build output; I did not call any of them, so the abuse paths in BK-4 are inferred from the code.

- **Dormant commerce, accounts and vouchers:** Provider facts: whether Stripe supports a Sierra Leone business, whether Moneroo covers Orange Money and Afrimoney Sierra Leone and which amount unit and signature format its API uses, and the GST and tourism-levy treatment of tours were not checked and need confirming with the providers and an accountant.
- **Dormant commerce, accounts and vouchers:** Provenance of vehicle rates and availability flags, tour ratings and review counts, and group sizes on the bookable tours is unknown; the owner must confirm.
- **Dormant commerce, accounts and vouchers:** Real HTTP status of unknown /booking and /tours slugs in production (dev server returned 200).
- **Dormant commerce, accounts and vouchers:** Whether enquiry email delivery (Resend) works in production. The enquiry-only model depends on it, because no admin user may exist yet to read the DB; this belongs to the enquiry dimension.
- **SEO and discoverability:** The live site was not fetched: the www versus apex redirect direction, the http to https redirect, real response headers, the actual og tags served in production and indexing status are unknown. The repo hard-codes the apex host while CLAUDE.md says the live host is www.
- **SEO and discoverability:** Production HTTP status for invalid slugs: the soft-404 evidence comes from the dev server. A production build was not run because it would write into the project, though it uses the same SSR path.
- **SEO and discoverability:** The 25 Sep .vercel/output server bundle was checked for the head injector, but whether that build matches what is deployed today is unknown.
- **SEO and discoverability:** Vercel domain settings and DNS (primary domain, redirects, SSL) cannot be seen from code and were not touched.
- **SEO and discoverability:** Google Business Profile: whether a profile exists, is claimed and verified, its categories and hours, and whether its name, address and phone match the site.
- **SEO and discoverability:** Search Console and Bing Webmaster state: no verification tag exists in the repo, but DNS or HTML-file verification would not appear in code, so whether a property exists is unknown.
- **SEO and discoverability:** Core Web Vitals, Lighthouse scores, real index coverage, rankings and backlinks: none were measured.
- **SEO and discoverability:** Structured-data validity in Google's Rich Results Test and Schema Validator: JSON-LD was read and parsed locally only, and social-card rendering in the Facebook, X or LinkedIn debuggers was not run.
- **SEO and discoverability:** What https://grok.com/grok-app-builder/extensions.js does when loaded: it was not fetched.
- **SEO and discoverability:** Whether the datePublished value 2024-12-20 on three journal articles is a real date or a migration placeholder.
- **SEO and discoverability:** Whether the trailing-slash redirect is 307 (as on the dev server) or 308 or 301 in production.
- **SEO and discoverability:** Provenance of /og.jpg: it looks illustrative or generated, but its origin cannot be determined from the repo.
- **Performance, accessibility and responsiveness:** Production behaviour: no requests were made to the live site, so the PERF-1 stylesheet mismatch, image and manifest cache headers, HTTP/2 and Brotli behaviour on Vercel, and the real CWV field data are NOT VERIFIED. The same SSR-versus-client CSS difference was seen in every local build I could inspect (three pairs), but Vercel's own build was not inspected.
- **Performance, accessibility and responsiveness:** What https://grok.com/grok-app-builder/extensions.js downloads, renders or sends: it was blocked in every Playwright run and never fetched.
- **Performance, accessibility and responsiveness:** Measurements ran on a scratch copy built from the current source (junction-linked node_modules, .env files excluded), served by vite preview on 127.0.0.1:8081 with NODE_OPTIONS=--unhandled-rejections=warn because the prod server without DATABASE_URL crashes in PGLite bootstrap. Only pages that do not need the database were exercised; account, admin, booking and search flows were not. vite preview speaks HTTP/1.1 and does not compress HTML, so the throttled numbers (slow 4G, CPU x4) are indicative and probably pessimistic for requests contending with images; the tour page's throttled FCP of 28.8 s was discarded for that reason.
- **Performance, accessibility and responsiveness:** Real low-end device behaviour (GPU cost of backdrop-filter glass layers and Ken Burns, decode memory of 2400 px images): only arithmetic estimates and desktop Edge were used. Lighthouse and a real screen reader (NVDA, VoiceOver) were not run; ARIA findings come from DOM inspection and scripted keyboard tests.
- **Performance, accessibility and responsiveness:** Contrast was computed from tokens for all four themes and rendered for default and Theme Two only; hero and card text contrast was deliberately not repeated. iOS choice between the two apple-touch-icon links was not tested on a device.
- **Performance, accessibility and responsiveness:** Side effects to disclose: my first build attempt used a node_modules junction and wrote cache files under the project's node_modules/.nitro (gitignored build cache only; no source file touched); the project's .vercel/output and node_modules/.nitro were also rewritten at 17:25-17:30 today by something other than my commands, so I relied on my scratch build for PERF-1. I briefly created a stray C:\c directory via a mis-resolved screenshot path and removed it after moving the PNGs into the scratchpad.

- **Quality assurance, CI/CD and repository health:** What is live on www.tourismislife.com. The brief allowed GETs only to the localhost dev server, so I did not fetch production. From the GitHub deployments API the last git-triggered Production deploy is 04aef64 (2026-09-22). A CLI-pushed prebuilt deploy would not appear there, so I cannot rule it out.
- **Quality assurance, CI/CD and repository health:** Vercel dashboard settings (build command, Node version, Preview-scope environment variables, which of the two historical projects still exists, log retention). No `vercel.json` exists and I did not query Vercel.
- **Quality assurance, CI/CD and repository health:** Neon settings: PITR or snapshot retention, branch list and plan. I made no Neon MCP calls.
- **Quality assurance, CI/CD and repository health:** Whether the running dev server is actually connected to the Neon production branch. I demonstrated the mechanism (the `loadEnv` plugin, the keys in `.env.local`, and the `dbSource` logic) but did not run a query. I also could not read the process's environment variables.
- **Quality assurance, CI/CD and repository health:** Disclosure: during a status probe I sent one GET to `http://localhost:8080/api/cron/expire-holds`. It returned 200 because the route is open when `CRON_SECRET` is unset and the runtime counts as a workspace preview. That route runs the idempotent `expireHolds` transaction, which updates only bookings in `HOLD` or `PENDING_PAYMENT` with a lapsed hold. I did not capture the response body. If the server is wired to Neon as analysed, that transaction ran against production. Online booking is dormant, so no rows are expected to have changed. I did not call it again.
- **Quality assurance, CI/CD and repository health:** Side effects of the build runs: `build:dev` and the production-mode ``vite build`` overwrote the gitignored `.vercel/output`. I backed it up first and restored it (425 files, same content, new mtimes). `src/routeTree.gen.ts` and ``git status`` were checked unchanged afterwards. A clean-room copy I created in the scratchpad is outside the project.
- **Quality assurance, CI/CD and repository health:** A Linux CI run. The workflow has never run, and my clean-room verification was on Windows. Two symlink tests are skipped on Windows and may run, and pass or fail, on Linux.
- **Quality assurance, CI/CD and repository health:** Whether Resend is configured and delivering enquiry emails in production. Only the code path and logging were reviewed.
- **Quality assurance, CI/CD and repository health:** Whether Vercel Preview deployments receive `DATABASE_URL`, which determines how exposed production is to `db:migrate` from previews.
- **Legal, compliance, brand and image rights:** The live production host (<https://www.tourismislife.com>): I only used `localhost:8080` and the local `.vercel/output` build. Whether the `grok.com` script, `Grok` manifest and install page appear in production HTML is inferred from the built bundle, not observed live.
- **Legal, compliance, brand and image rights:** What `https://grok.com/grok-app-builder/extensions.js` actually does: I did not fetch or read it. Whether the `'__cf_bm'` cookie behaves the same in production is not confirmed.
- **Legal, compliance, brand and image rights:** Pexels and Pixabay licence terms, photographer names and photo IDs: I used only the IDs in `scripts/download-vehicle-images.mjs` and did not visit those pages.
- **Legal, compliance, brand and image rights:** Whether the Wikimedia Commons pages for the 16 'Unknown' author images really list no author: I did not fetch Commons.
- **Legal, compliance, brand and image rights:** Production environment variables on Vercel (whether `RESEND_API_KEY`, `TWILIO_*`, `UPSTASH_REDIS_*` are set). `.env.local` holds only `DATABASE_URL`, `DATABASE_URL_UNPOOLED`, `NEON_BRANCH` and `VERCEL_OIDC_TOKEN`, so the processor list in the privacy policy cannot be checked against reality.
- **Legal, compliance, brand and image rights:** Database contents: I did not query Neon, so subscriber counts, enquiry volume and retention in practice are unknown.
- **Legal, compliance, brand and image rights:** The current data-protection law and regulator in Sierra Leone, and which foreign laws (GDPR, UK GDPR, others) apply to this site's visitors: that is a lawyer's call.
- **Legal, compliance, brand and image rights:** Whether the four social profiles, the Travel And Tour World and AFAR articles, and 1 DCM World membership exist and are the company's: not visited.
- **Legal, compliance, brand and image rights:** Whether 'Sign in with Grok' gate sessions (`x-grok-identity`) can exist on the Vercel host, and whether the `'__Host-grok-auth.*'` cookies and `'grok-auth.bearer-token'` sessionStorage key ever appear for a real visitor: I did not sign in.
- **Legal, compliance, brand and image rights:** Whether the logo and `public/og.jpg` are generated or commissioned: judged only by looking at them.
- **Legal, compliance, brand and image rights:** Legal sufficiency of any wording on the privacy, terms or cookies pages: I checked it against the code, not against any statute.